

**A COMPREHENSIVE FRAMEWORK FOR MIGRATING TO
ZERO TRUST ARCHITECTURE**

The seal of Mahidol University is a circular emblem. It features a central five-tiered umbrella (parasol) with a flame-like base. The entire emblem is encircled by a ring containing the university's name in Thai script: "มหาวิทยาลัยมหิดล" (Mahavithayalai Mahidol) at the top and "พุทธทาสภวน์" (Phra Prasa) at the bottom. There are four small decorative floral motifs positioned between the top and bottom text on the ring.

PACHAREE PHIAYURA

**A THESIS SUBMITTED IN PARTIAL FULFILLMENT OF THE
REQUIREMENTS FOR
THE DEGREE OF MASTER OF SCIENCE
(CYBER SECURITY AND INFORMATION ASSURANCE)
FACULTY OF GRADUATE STUDIES
MAHIDOL UNIVERSITY**

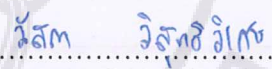
Copyright by Mahidol University

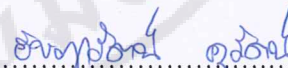
COPYRIGHT OF MAHIDOL UNIVERSITY

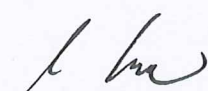
Thesis Paper
entitled
**A COMPREHENSIVE FRAMEWORK FOR MIGRATING TO
ZERO TRUST ARCHITECTURE**

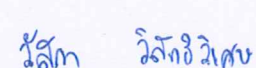

.....
Miss Pacharee Phiayura
Candidate


.....
Songpon Teerakanok,
D.Eng. (Information Science and
Engineering)
Major advisor


.....
Assoc. Prof. Vasaka Visoottiviseth,
Ph.D.(Computer Engineering)
Co-advisor


.....
Assadarat Khurat,
Ph.D.(Computer Security)
Co-advisor


.....
Prof. Patcharee Lertrit,
M.D., Ph.D.(Biochemistry)
Dean
Faculty of Graduate Studies
Mahidol University

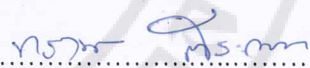

.....
Assoc. Prof. Vasaka Visoottiviseth,
Ph.D.(Computer Engineering)
Program Director
Master of Science Program in Cyber
Security and Information Assurance
Faculty of Information and
Communication Technology
Mahidol University

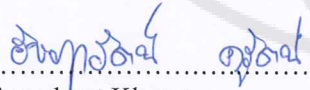
Thesis
entitled
**A COMPREHENSIVE FRAMEWORK FOR MIGRATING TO
ZERO TRUST ARCHITECTURE**

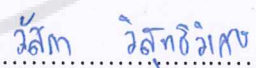
was submitted to the Faculty of Graduate Studies, Mahidol University
for the degree of Master of Science (Cyber Security and Information Assurance)
on
January 7, 2023


.....
Miss Pacharee Phiayura
Candidate


.....
Chalee Vorakulpipat,
Ph.D. (Information Systems)
Chair


.....
Songpon Teerakanok,
D.Eng. (Information Science and
Engineering Member


.....
Assadarat Khurat,
Ph.D.(Computer Security)
Member


.....
Assoc. Prof. Vasaka Visoottiviseth,
Ph.D.(Computer Engineering)
Member


.....
Prof. Patcharee Lertrit,
M.D., Ph.D.(Biochemistry)
Dean
Faculty of Graduate Studies
Mahidol University


.....
Pattanasak Mongkolwat,
Ph.D.(Computer Science)
Dean
Faculty of Information and
Communication Technology
Mahidol University

ACKNOWLEDGEMENTS

I would like to express my gratitude to my advisor Dr. Songpon Teerakanok for the support, suggestions, and encouragement for my research. His guidance, immense knowledge and generous feedback carried me through all stages of my research from the first day to completion.

Besides my advisor, I wish to express my appreciation and extend my special thanks to my thesis committee Assoc. Prof. Vasaka Visoottiviseth and Dr. Assadarat Khurat who offer invaluable suggestions and insightful feedback for my master's study and research.

Finally, I would like to give my warmest thanks to my family and partner for understanding, giving love, and continuous support throughout my academic journey.

Pacharee Phiayura

A COMPREHENSIVE FRAMEWORK FOR MIGRATING TO ZERO TRUST ARCHITECTURE

PACHAREE PHIAYURA 6338406 ITCY/M

M.Sc.(CYBER SECURITY AND INFORMATION ASSURANCE)

THESIS ADVISORY COMMITTEE : SONGPON TEERAKANOK, D.Eng.,
VASAKA VISOOTTIVISETH, Ph.D., ASSADARAT KHURAT, Ph.D.

ABSTRACT

Migrating to Zero Trust Architecture (ZTA) is a strategic approach to strengthen the security postures within the organization. Moving to Zero Trust (ZT) involves changes across the organization and it can be challenging to achieve. Utilizing effective and reliable frameworks for migrating from the old security architecture to ZTA can help ensure a smooth transition and risk mitigation to the Zero Trust journey. This study aimed (1) to develop a comprehensive framework for migrating to ZTA and (2) to create a guideline that aligns with a proposed framework for supporting the ZT migration plan. This study was conducted by using a meta-analysis by following a PRISMA guideline to analyze and synthesize the published studies relating to ZT migration. Online databases for data extraction included IEEE Explore, ScienceDirect, ACM Digital Library, Web of Science, JSTOR, SpringerLink, and Google Search Engine. In this research, 635 academic publications and practice-oriented publications, including white papers and reports from ZT vendors, published during 2015-2022 were retrieved. Finally, 28 academic literature and high-quality reports regarding ZT migration were obtained. Using the extracted, categorized, and consolidated ZT migration knowledge from these literatures, a comprehensive framework for ZTA migration was created. Furthermore, the proposed framework was completed by incorporating DevOps concepts that concern the entire migration lifecycle. Ultimately, the proposed framework was evaluated its usability and effectiveness by assessing with generic and ZTA-specific criteria of the framework evaluation.

The results of meta-analysis revealed that ZT migration started with developing strategies, evaluating the current security state and setting the desired security state before deploying ZTA. Later, the organization implemented ZT components and migrated users to ZTA. Finally, the organization monitored and optimized the security performance of ZTA. Thus, based on the meta-analysis results, a comprehensive framework for migrating to ZTA should be composed of six main processes: (1) strategize zero trust, (2) context assessment, (3) architect ZTA, (4) zero trust transformation, (5) monitoring and maintenance, and (6) optimize ZTA security. In addition, the proposed guidelines provided practical checklists that specified important activities for ZT migration and technological requirements to implement ZTA in the organization.

IMPLICATION OF THESIS

The results of this study can assist organizations wishing to migrate from the traditional security architecture to ZTA. The proposed framework provides an efficient and consistent model for organizations to establish migration strategies. Moreover, the proposed framework is applicable for IT managers to have practical and effective processes for supporting the ZT migration. Thus, IT managers can use the proposed framework and the guideline of this study to implement the ZT migration projects and continue to optimize ZTA's security capabilities.

KEY WORDS: ZERO TRUST / ZERO TRUST ARCHITECTURE / ZTA/
ZERO TRUST MIGRATION / ZERO TRUST CHALLENGE

115 pages

CONTENTS

	Page
ACKNOWLEDGEMENTS	iii
ABSTRACT	iv
LIST OF TABLES	x
LIST OF FIGURES	xi
CHAPTER I INTRODUCTION	1
1.1 Motivation	1
1.2 Problem Statement	2
1.3 Research Questions	2
1.4 Objectives	3
1.5 Scope	3
1.6 Structure of the Project	3
CHAPTER II FUNDAMENTAL KNOWLEDGE AND BACKGROUND	4
2.1 Perimeter-Based Network Security Overview	4
2.1.1 Overview	4
2.1.2 Issues and Challenges	5
2.2 What is Zero Trust Architecture?	6
2.2.1 Definition of Zero Trust Architecture (ZTA)	6
2.2.2 Perimeter-based Model vs Zero Trust Architecture Model	6
2.2.3 History and Evolution of Zero Trust Architecture	7
2.2.4 Core Principles	7
2.2.5 Advantages of Zero Trust Architecture	8
2.2.6 Disadvantages of Zero Trust Architecture	9
2.2.7 Logical Components of Zero Trust Architecture	9
2.2.8 The Zero Trust eXtended (ZTX) Capabilities	12

CONTENTS (cont.)

	Page
CHAPTER III CHALLENGES IN MIGRATION TO ZTA AND RELATED WORK	14
3.1 Summary of Migration Process	14
3.2 Case Studies	15
3.2.1 BeyondCorp	16
3.2.2 NIST	17
3.2.3 Microsoft	18
3.2.4 Forrester	19
3.3 ZT Migration Challenges	20
CHAPTER IV RESEARCH METHODOLOGY	25
4.1 A Systematic Review (PRISMA)	25
4.1.1 Identification of studies via academic database	27
4.1.2 Identification of studies via other methods	27
4.2 Framework Design Methodology	28
4.2.1 Analyze Findings	30
4.2.2 Formulate a Draft Framework	31
4.2.3 Identify Challenges and Other Migration Frameworks Gaps	31
4.2.4 Optimize a Draft Framework by Incorporating Other Technological Migration Framework	40
4.2.5 Evaluate a Proposed ZT Migration Framework	41
CHAPTER V A PROPOSED ZTA MIGRATION FRAMEWORK	43
5.1 Incorporating DevOps Methodology	43
5.2 A Proposed Comprehensive ZTA Migration Framework	44
5.2.1 Process I – Strategize Zero Trust	46
5.2.2 Process II – Context Assessment	47
5.2.3 Process III – Architect ZTA	49

CONTENTS (cont.)

	Page
5.2.4 Process IV – Zero Trust Transformation	51
5.2.5 Process V – Monitoring and Maintenance	54
5.2.6 Process VI – Optimize ZTA Security	55
CHAPTER VI FRAMEWORK EVALUATION AND RESULTS	57
6.1 Framework Evaluation	57
6.1.1 Generic Criteria for Evaluation	58
6.1.2 ZTA-specific Criteria for Evaluation	63
6.2 Evaluation Results	66
6.2.1 The Results of Generic Criteria for Evaluation	66
6.2.2 The Results of ZTA-specific Criteria for Evaluation	72
CHAPTER VII DISCUSSION AND CONCLUSION	77
7.1 Discussion	77
7.1.1 The PRISMA Systematic Review Results	77
7.1.2 The Gaps of Other ZTA Migration Frameworks	78
7.1.3 The Evaluation Results of Other ZTA Migration Frameworks	79
7.1.4 The Evaluation Results of The Proposed Framework	81
7.1.5 ZTA Migration in the Cloud Environment	82
7.2 Limitations	84
7.2.1 Publication Bias	84
7.2.2 Framework Validation	85
7.3 Conclusion	85
7.4 Future Works	86

CONTENTS (cont.)

	Page
REFERENCES	87
APPENDIX	93
Appendix A	94
Appendix B	95
Appendix C	103
BIOGRAPHY	115

LIST OF TABLES

Table	Page
3.1 List of ZT Migration Challenges	21
4.1 Process Description of Each ZTA Migration Process	30
4.2 ZT Migration Challenges	32
4.3 Identification of gaps showing what is lacking in other frameworks	34
4.4 Identify findings to address and overcome ZTA migration challenges	35
6.1 Framework Evaluation – Generic Criteria	61
6.2 A List of ZT Migration Challenges	63
6.3 Framework Evaluation – ZTA-specific Criteria	63
6.4 Evaluation Result – General Criteria	67
6.5 Evaluation Result – Development Roles	68
6.6 Evaluation Result – Work Product	69
6.7 Evaluation Result – Formality	70
6.8 Evaluation Result – Theoretical Foundation	70
6.9 Evaluation Result – Scalability	71
6.10 Evaluation Result – Domain Applicability	72
6.11 Evaluation Result – ZTA-specific criteria	73
A-1 Quality assessment checklist of grey literature for software engineering [24]	94
B-1 Identification of Studies via Academic Database	95
B-2 Identification of Studies via Other Methods	97
B-3 Main Concepts of Obtained Studies	99

LIST OF FIGURES

Figure	Page
2.1 Zero Trust Access [13]	10
2.2 Logical Components of ZTA [13]	10
2.3 The Zero trust eXtended ecosystem capability [19]	12
3.1 Summary of ZT Migration Process	14
3.2 ZTA Migration by BeyondCorp [16]	16
3.3 ZTA Deployment Cycle [13]	17
3.4 The Zero Trust Pillars [22]	18
4.1 The PRISMA flowchart showing the process of how we select and obtain the literature for our study. [25]	26
4.2 A Framework Design Methodology	28
4.3 An Overview of ZTA Migration Process	31
4.4 Evaluation Framework	42
5.1 DevOps Cycle	43
5.2 A Proposed Comprehensive Framework for Migrating to ZTA	45
5.3 The main processes and sub-processes of ZTA migration	45
5.4 Process I – Strategize Zero Trust	46
5.5 Process II – Context Assessment	47
5.6 Process III – Architect ZTA	49
5.7 Process IV – Zero Trust Transformation	51
5.8 Process V – Monitoring and Maintenance	54
5.9 Process VI – Optimize ZTA Security	55
6.1 Framework Evaluation Criteria	57
7.1 The Gaps of Other ZTA Migration Frameworks	78
7.2 The Six Processes of ZTA Migration	79
7.3 Generic criteria – Evaluation results of the proposed framework	81

LIST OF FIGURES (cont.)

Figure		Page
7.4	ZTA-specific criteria – Evaluation results of the proposed framework	82
7.5	ZTA Cloud access control via co-located PEP [24]	83
7.6	Cloud access control via remote PEP [24]	84

CHAPTER I

INTRODUCTION

This chapter provides motivation, problem statement, research questions, research objectives, scope of work, and structure of the study.

1.1 Motivation

The growth and expansion of IoT devices, cloud technologies, and remote workforce are widening the border of the perimeter of an enterprise network environment. As a result, the traditional approach, a perimeter-based model that trusted anyone inside the corporate network perimeter, is obsolete.

The security strategy of zero trust architecture (ZTA) is adopted to address the risks of increasing cybercrimes, security breaches, and cyber threats in the era of digital transformation. Zero trust (ZT) assumes there is no trusted perimeter. Devices and users only receive the least privileged access. Furthermore, Zero Trust is a security strategy emphasizing continuous verification when users access resources no matter the request location. [1]. These can help increase visibility and analytics throughout the enterprise.

With the trends of remote and hybrid workplaces, organizations are driven to embrace Zero Trust Architecture to enhance security visibility and controls to overcome the challenges of revenue loss and data loss risks. According to the survey by Ericom Software [2], 83% of 1,300 security and risk professionals' respondents said Zero Trust is the essential strategy. Due to this reason, they plan to enable Zero Trust solutions in their organizations.

However, migrating to Zero Trust architecture is challenging, and it can be a long journey. Many challenges and roadblocks can hinder organizations from successfully migrating to a Zero Trust ecosystem. One of the main challenges is that currently, there are no industry standards or concrete ideas on how to implement the

Zero Trust strategy in organizations efficiently [3]. Moreover, the Zero Trust vendors developed most of the migration plans and techniques. The plans also include proposed Zero Trust systems of the vendors. Hence, it is considered a vendor lock-in approach that does not provide a holistic view of the Zero Trust migration in unbiased methods [4]. Furthermore, moving to Zero Trust architecture requires interoperability and compatibility of IT systems. Therefore, it is essential to understand infrastructure requirements before migrating to Zero Trust architecture [5].

The aims of this study are to study existing knowledge, methods, and techniques of the Zero Trust architecture migration by applying a systematic review for analysis and synthesis of the published studies. The results from analysis of published studies will form a process-driven framework for the Zero Trust architecture migration. Furthermore, the analysis shall argue the need for a comprehensive Zero Trust migration and identify the migration challenges and what is lacking in the existing frameworks. As a result, an appropriate Zero Trust migration framework shall be developed to establish effective processes that serve as a reference model to support a smooth transition to Zero Trust Architecture.

1.2 Problem Statement

The move to Zero Trust Architecture (ZTA) can be challenging. It requires thoughtful implementation plans and leveraging appropriate technology. Currently, there are no efficient and comprehensive frameworks, methods, or processes that provide thorough migration plans for ZTA. Thus, it is essential to use a practical and comprehensive framework for migrating to ZTA as it can reduce risks and provide a smooth transitioning to ZTA.

1.3 Research Question

In this research, we aim to answer the following questions:

- What are the existing methods or processes of ZTA migration?
- What are the ZTA issues and migration challenges that can hinder migration success?
- What are the gaps in other ZTA migration frameworks?

- What is a comprehensive ZTA migration framework that provide efficient migration processes?

1.3 Objectives

The main objectives of this study are as follows:

- This study shall develop a comprehensive framework for migrating to Zero Trust Architecture in which the developed framework shall take consideration of essential components and provide an effective process-driven for Zero Trust Architecture migration.
- This study shall develop a guideline that aligns with a proposed Zero Trust migration framework for supporting the Zero Trust migration plan.

1.4 Scope

The scope of this study are as follows:

- 1) This study will be conducted by using a meta-analysis method to obtain relevant studies for our analysis. The databases we use for our study include:
 - Well-established database: IEEE Explore, ScienceDirect, Web of Science, ACM Digital Library, JSTOR, SpringerLink
 - Google Search Engine
- 2) The findings will be analyzed and synthesized by using the PRISMA method (The Preferred Reporting Items for Systematic reviews and Meta-Analyses)

1.5 Structure of the Project

The structure of this research project is as follows. First, the fundamental knowledge and background is presented in Chapter 2. The challenges in migration to Zero Trust Architecture (ZTA) and related works are described in Chapter 3. The research methodology is shown in Chapter 4. The Chapter 5 shows a proposed ZTA migration framework. The framework evaluation and results are described in Chapter 6. Lastly, discussion, conclusion and future work and will be discussed in Chapter 7.

CHAPTER II

FUNDAMENTAL KNOWLEDGE AND BACKGROUNDS

This chapter firstly describes perimeter-based network security and discusses the issues and challenges of this network security model. Secondly, this chapter explains the fundamental knowledge of ZTA by providing its definition and comparing the perimeter-based model and the ZTA model. Thirdly, the history and evolution of ZTA, core principles, and advantages are described. Finally, the logical components of ZTA and the Zero Trust eXtended (ZTX) capabilities are illustrated.

2.1 Perimeter-Based Network Security Overview

2.1.1 Overview

Perimeter-based network security or a network perimeter is traditional network security that segments networks into zones. Each zone is given a trust level, indicating network resources allowed to access [6]. This network model breaks the protected barrier between the private and public network, for example internet and intranet. Therefore, it is the basic defense-in-depth principle that safeguards internal resources from external risks.

A network perimeter includes:

Border Routers: it works as the network's traffic lights managing traffic flows across the network [7].

Firewalls: it is a security point between a private network and the internet. The firewall contains a set of rules to evaluate packets entering and departing the network. It determines whether to allow or prohibit network traffic [8].

Intrusion Detection System (IDS)/ Intrusion Prevention System (IPS): the systems are used to monitor and detect unusual and suspicious

activities. These systems will automatically alert and defend against potential attacks [7].

De-Militarized Zones (DMZ): it is a designated area between the internal network and the network connecting to the internet. It contains public services such as public web, mail server, and DNS server and directly connects to a firewall or other filtering tools [8].

2.1.2 Issues and Challenges

1) Remote Workforce

Nowadays, the remote workforce is growing, and this trend will continue to increase. However, it becomes harder for organizations to secure an IT environment with a perimeter-based network model. Users connect to the network from many places such as homes, airports, restaurants, etc. [9]. Consequently, security solutions had to evolve to meet the remote working needs.

2) Compromised Credential

Attackers now use advanced techniques and mechanisms to compromise user accounts and credentials. Once they gain access to the network, they may perform lateral movement to critical applications and potentially extend the privilege to the system administrative roles [9]. Moreover, when the attackers have compromised the network, lateral movement might be difficult to detect. Owing to the high number of compromised credential attacks, a traditional perimeter network model may not be efficient to protect organizations from these attacks.

3) Adoption of Cloud Computing

With the growth of cloud computing adoption, many organizations use cloud infrastructure and services in their businesses. As a result, users can access information or applications from cloud data centers via multiple devices from any place [10]. However, enterprises have limited controls over the cloud, and the perimeter network security becomes less efficient and outdated.

The digital transformations and remote workforce are the main driving factors for organizations to find a new security mindset and security model to meet users'

needs. As the perimeter security model is ineffective, the zero-trust security comes into play.

2.2 What is Zero Trust Architecture?

2.2.1 Definition of Zero Trust Architecture (ZTA)

ZTA emphasizes the security concept that there is no implicit trust between different entities. The entities inside or outside the enterprise network have no trust. [11]. Additionally, identity is the starting verification process of ZTA, where the flow is from identity, device, and context to grant trust to users [12]. In practice, ZTA's goal is to ensure that sensitive data is not discoverable by an unauthorized person.

The National Institute of Standards and Technology (NIST) [13] defines that *“Zero trust architecture (ZTA) is an enterprise’s cybersecurity plan that utilizes zero trust concepts and encompasses component relationships, workflow planning, and access policies. Therefore, a zero-trust enterprise is the network infrastructure (physical and virtual) and operational policies that are in place for an enterprise as a product of a zero-trust architecture plan.”*

2.2.2 Perimeter-based Model vs Zero Trust Architecture Model

Perimeter-based security is a conventional security model that organizations focus on protecting internal data and systems from external intruders. The perimeter model separates resources into trusted and untrusted zones such as intranet and internet. Additionally, the level of trust is assigned to users and resources to protect the network. Everything inside the cooperate network and internal users often have some level of privilege or are given implicated trust in accessing the company’s resources [6].

In contrast, the Zero Trust model emphasizes the least privilege concept where there are no trusted zones, and no one is trusted. Every entity is assumed to breach, and it is likely to occur. Therefore, strong authentication methods and network segmentation are required to prevent the lateral movement of attackers [6].

2.2.3 History and Evolution of Zero Trust Architecture

Forrester Research introduced the term “Zero Trust” in 2009. The trend of a perimeter model is shifting to a strategy requiring an inspection before gaining trust level to access resources. Later, Forrester developed the Zero Trust eXtended (ZTX) Framework, which incorporates identity, devices, data, and workloads as fundamental Zero Trust security capabilities [3].

In 2014, Google started the BeyondCorp program that use the concepts of ZTA to implement within its enterprise. The BeyondCorp published series of articles for their internal Zero Trust migration to influence the industry. The number of products and solutions branded as “Zero Trust” expanded dramatically. In 2020, the US National Institute of Standards and Technology (NIST) published a Zero Trust Architecture publication. The NIST SP-800-207 describes the fundamentals of ZTA. The core concepts and principles of ZTA are clarified in this publication [13].

As the business and standard bodies recognize and emphasize the concepts of Zero Trust, it will continue to evolve the industry in an approach to secure and protect information security of organizations.

2.2.4 Core Principles

1) Least Privilege

The least privilege is a security principle emphasizing granting users the level of access they need. It helps reduce the exposure of sensitive areas of the network to unauthorized users. Applying the least privilege requires proper management of user permissions. For ZTA, user credentials alone are not sufficient to authenticate to get access. It also requires security posture to be evaluated for granting access [14].

2) Continuous Verification

The phrase “Never Trust, Always Verify” implies key elements of ZTA that there is no trusted zone. No one or any device is trusted. Therefore, Continuous verification must be applied for all resources all the time. Furthermore, it will incorporate analyzed data of behavioral and context assessment of resources in real-time [14]. As a result, the user access is granted by the risk-based conditional access.

3) Assume Breach

Assume breach means trying to limit the scope and consequence of the attacks by emphasizing the importance of micro-segmentation. For this practice, security perimeters are segmented into small zones to minimize the impact of breaches [14]. Hence, it can help limit access pathways of attackers and allow an organization to have time to respond and mitigate the attack.

2.2.5 Advantages of Zero Trust Architecture

1) Improve Data Protection

In a Zero Trust environment, the enterprise shall consider a data-centric approach in which they should know and identify their data. In addition, the enterprise must have visibility of how data is protected and who can access services. Data discovery can help track and analyze data flows and show data visibility [15]. Besides, adopting ZTA in the enterprise can help ensure that sensitive information is not discovered [12]. Moreover, having ZTA can help guarantee secure data exchange between the enterprise's external and internal networks.

2) Streamline User Access

B. Enbrey (2020) [15] states that ZTA can provide better efficiency and security of entity verification. Since it is crucial that all devices and user profiles have to meet access controls and security requirements. It can be done through identification and authentication technologies such as multifactor authentication (MFA) or single-sign-on (SSO). Furthermore, ZTA enforce least privilege access in which users can access only services they need with specific segmentations.

3) Gain Greater Visibility Across the Enterprise

The goal of ZTA is to discover and classify data, data workflows, and business processes [13]. Moreover, devices and identity also need to achieve visibility for control solutions. For example, mobile devices and BYOD must be registered in the device inventory database before using in the enterprise. In addition, each user needs to have profile registration on the user database to ensure granting permission to the authorized person [16].

2.2.6 Disadvantages of Zero Trust Architecture

1) System Complexity

The most significant disadvantage of ZTA is that it is a complex system, as all users, devices, systems, and applications require authentications. It can be challenging to implement, especially in large organizations. In addition, it also requires a mindset shift from the traditional perimeter model to focus on the contextual-based analysis of security postures. Another issue is that the network in ZTA should be granular as possible. As a result, the enterprise requires more workforce, such as IT and security teams, to manage ZTA [17].

2) ZTA is Costly

Another issue of ZTA is the ZT systems are costly. The ZTA requires updating or changing many things, for example, identity and device security, security policies, and workflow processes. Continuously making changes to add security measures are costly and needs a complete understanding of technical requirements. Thus, ZTA may not be necessary for enterprises that do not require highly secure systems to protect all data and resources [17][18].

3) Hinder Productivity

ZTA may sometimes hinder productivity as the systems add additional security measures. In some scenarios, it may cause user friction and decrease user experience. For example, when users fail for authentication and cannot access what they want to access due to adaptive security policies [17].

2.2.7 Logical Components of Zero Trust Architecture [13]

ZTA focuses on authentication, authorization, and minimizing trusted zones. Access to data and service is permitted by a policy decision point (PDP) a policy enforcement point (PEP) [13], as illustrated in figure 2.1.

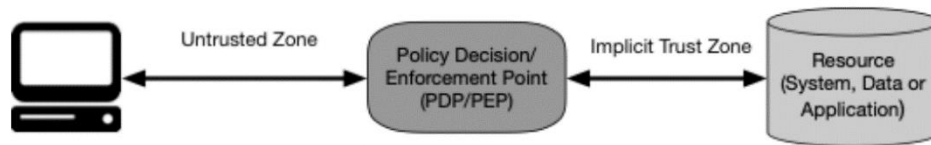


Figure 2.1: Zero Trust Access [13]

A ZTA deployment comprises many logical components, as illustrated in Figure 2.2. The picture depicts the essential connection between these components in a conceptual model. The components of ZTA can run and support on-premises or cloud environments.

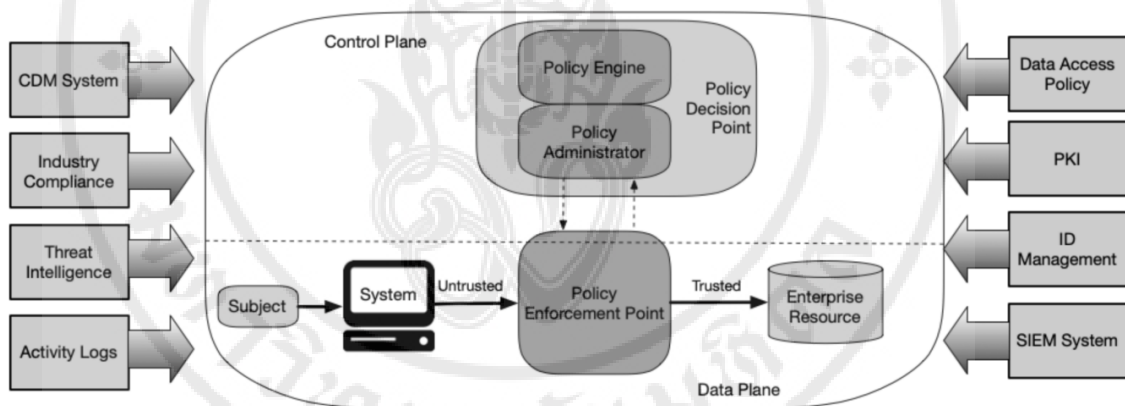


Figure 2.2: Logical Components of ZTA [13]

Logical Components of ZTA includes [13]:

Policy engine (PE): This component will make decision to grant access to a subject. The PE uses information from enterprise policy and other sources to grant or deny access to a subject.

Policy administrator (PA): The PA will perform the task to start or end the communication between a subject and resources.

Policy enforcement point (PEP): The PEP works with the PA to forward access requests and the PA will provide policy updates back to the PEP.

Continuous diagnostics and mitigation (CDM) system: This system is responsible for collecting information regarding current the conditions of the enterprise assets. Then it will apply updates on configurations.

Industry compliance system: This component helps guarantee that any regulatory requirements will be complied. All the policies created by an enterprise are also included in this system.

Threat intelligence feed(s): The information is gathered from various sources, including internal and external sources. This information will help support the PE in making an appropriate decision.

Network and system activity logs: This component is used to gather information about network activities, such as asset logs, access logs, and other activities providing security events' information.

Data access policies: This system is to set policy rules that establish and authorize access to resources. The least privilege principle should be applied to users and systems of the enterprise.

Enterprise public key infrastructure (PKI): The PKI is used to issue certificates to various systems such as subjects, resources, and applications in the enterprise.

ID management system: This system is used to create, store, and manage user accounts and identity information.

Security information and event management (SIEM) system: SIEM is a system that gathers and analyzes security events. The information gathering from this system is used to update access policies and notify the enterprise regarding potential attacks.

2.2.8 The Zero Trust eXtended (ZTX) Capabilities

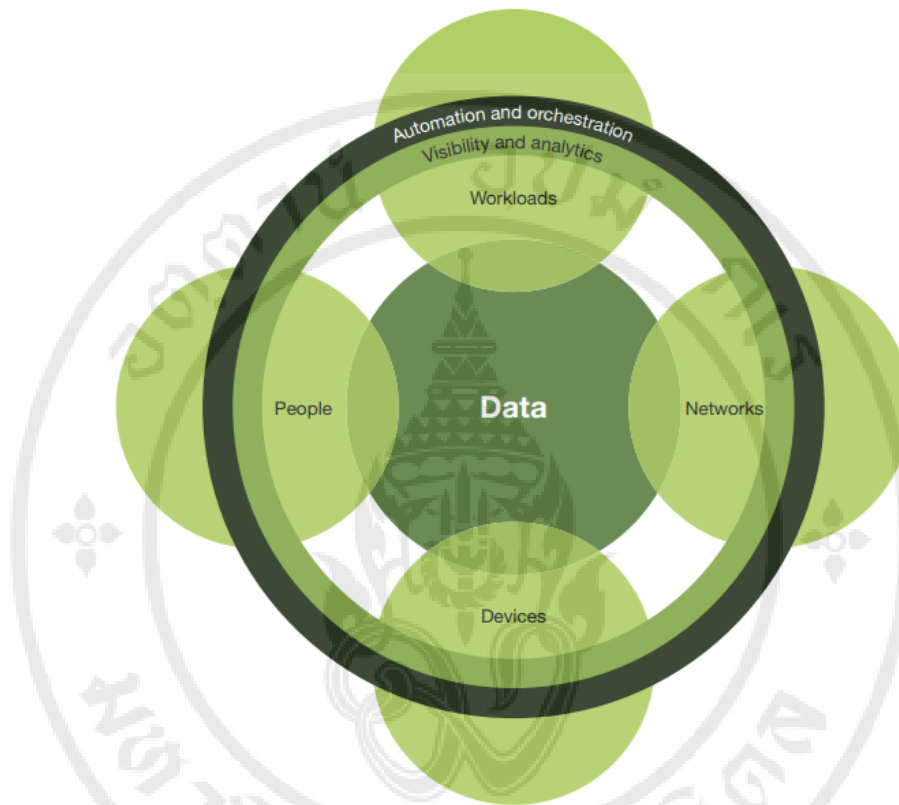


Figure 2.3: The Zero trust eXtended ecosystem capability [19]

The Zero trust eXtended (ZTX) ecosystem Framework is developed by Forrester Research. This framework highlight main components of the Zero Trust eXtended (ZTX) platform. This ZTX platform comprises of seven essential components for mapping products and solutions relating to ZT strategy [19]. The ZTA platform was created to support businesses when making decisions and determine which tools and technologies are available in this domain.

These seven capabilities are summarized as [19]:

People: This refers to identity capability involves the technology for user identification and authentication. This system will secure, manage and monitor users with access control policies. In addition, the identity system will grant

access based on dynamic and contextual data analysis when users attempt to access services.

Devices: This capability is to ensure appropriate device management and endpoint security. It is to perform device validation to verify the security posture and trustworthiness of user-controlled devices. It is crucial to continuous monitoring device health and compliance to maintain secure access.

Networks: This domain emphasize network segmentation in order to isolate and control the network. The goal is for preventing unauthorized users from accessing sensitive resources of an enterprise. An enterprise should deploy techniques such as micro-segmentation and end-to-end encryption to help prevent attackers from accessing sensitive information.

Data: This capability focuses on managing and securing data. Data should be classified and encrypted to remain safe both at rest and in transit. Moreover, access to data should be enforced based on data classification and provide access to those that need the access.

Workloads: The workloads are systems are services that operate to run the business. It is vital to ensure workloads are protected from unauthorized access and possible vulnerabilities. Each workload should be protected to prevent unauthorized access, data leakage, and service tampering.

Visibilities and Analytics: It refers to the capability of tools or systems that enable a security team to precisely and intelligently monitor and assess potential threats. In addition, it is crucial to gather and analyze security events across the network. These tools include security information management systems, user behavior analytics, and other analytic systems.

Automation and Orchestration: An enterprise should leverage and utilize automation and orchestration tools across the enterprise. This ability will provide more excellent command and control over several components of the Zero Trust ecosystem.

CHAPTER III

CHALLENGES IN MIGRATION TO ZTA AND RELATED WORKS

This chapter firstly illustrates an overview of the ZT migration process by summarizing communal methods from several studies. Secondly, the four case studies of migration techniques are described. Finally, this chapter explains key migration challenges an enterprise may experience when moving to ZTA.

3.1 Summary of Migration Process

Many studies have outlined their methods and techniques to migrate to ZTA. In this study, we point out and summarize key methods and processes that many studies have communal methods when migrating to ZTA, as shown in figure 3.1.

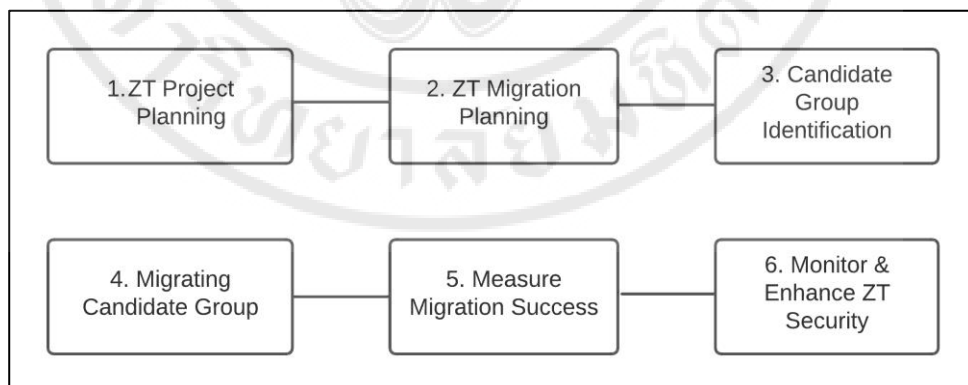


Figure 3.1: Summary of ZT Migration Process

The following each ZT migration process are summarized:

1) ZT Project Planning

This process involves gaining the top management and stakeholders' buy-in with ZT initiatives. First, an enterprise should define the vision and goals of ZT that they want to achieve. Furthermore, the enterprise should develop the ZT project plan that defines budgets, implementation scope, and implementation team.

2) ZT Migration Planning

Having a good ZT migration plan is essential for the success of ZT migration. In this plan, an enterprise should identify data, assets, and applications in this process. Moreover, the enterprise should map data flows and business processes to gain their resources' visibility. Then, the enterprise can set the target ZT architecture and requirements.

3) Candidate Group Identification

This process concerns setting up a pilot program for the migration. An enterprise should prioritize groups of users for migration and choose the test group as the first group for migration.

4) Migrating Candidate Group

This process involves implementing the main ZTA components, including technologies or solutions relating to securing identity, device, network, and applications and services. In addition, ZT policies also need to be created to define the authorized connections.

5) Measure Migration Success

It is crucial to test the migrated systems to validate proper functionalities. In this process, an enterprise should evaluate some security interruptions of its deployment milestones and track the improvement of security postures.

6) Monitor and Enhance ZT Security

An enterprise should monitor and maintain the ZT ecosystem after successfully migrating to ZTA. Moreover, the enterprise should properly provide user supports to accommodate any errors and issues causing users' productivity. Finally, the enterprise should prepare to enhance its ZTA by adopting automation and orchestration systems.

3.2 Case Studies

This section summarizes ZT migration techniques by reviewing four case studies that explain migration methods based on their experiences and expertise, namely BeyondCorp, NIST, Microsoft, and Forrester.

3.2.1 BeyondCorp

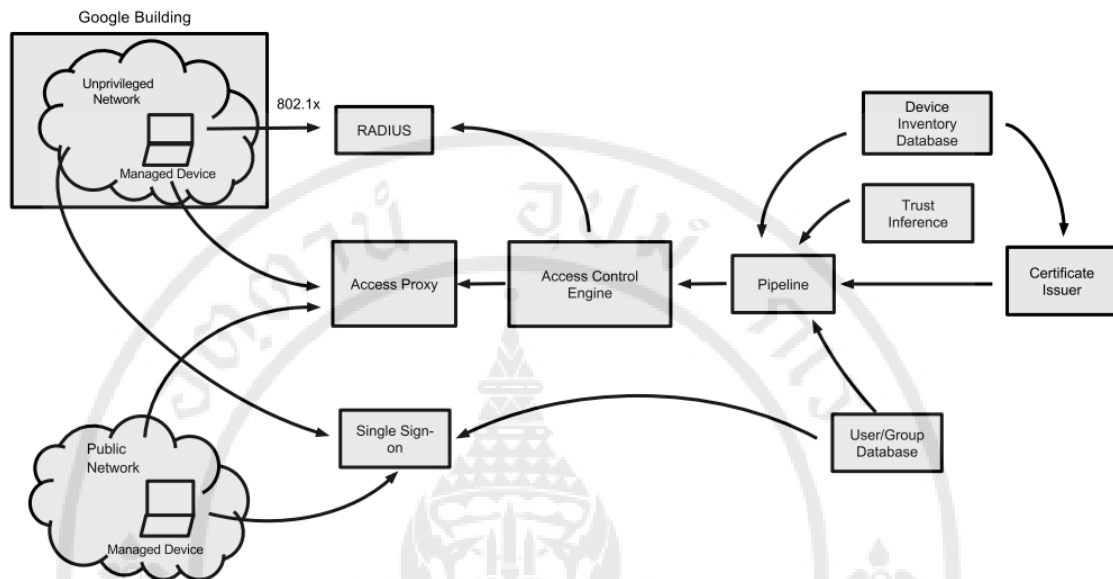


Figure 3.2: ZTA Migration by BeyondCorp [16]

Google initiated the BeyondCorp program in 2014. Regarding ZTA migration at BeyondCorp, the initial process started from getting top-level management and stakeholders' buy-in. BeyondCorp also had a communication plan regarding this migration within the organization. In the technical aspects, the initial stage of ZTA migration was migrating VLAN across the enterprise. Certificates are installed to user devices to use 802.1x to grant access. [16].

BeyondCorp began its migration as a small project. The migration of this pilot project is executed in close collaboration with the migration team. The main concerns of BeyondCorp's Zero Trust are securely identifying the device and the user. To securely identify the device, all devices are registered in the Device Inventory Database so that it can ensure only authorized devices can access enterprise resources.

To securely identify users, users' profiles are registered in the User and Group Database. This database is integrated with HR management to manage job functions and the group membership of users. In addition, they use Single Sign-On System (SSO). This system will issue tokens for users to authenticate and authorize users to access resources.

In the next stage, they remove trust from the network so that the unprivileged network can be deployed. Moreover, devices are assigned to the appropriate network by RADIUS servers and 802.1x authentication. Then, applications and workflows were externalized. BeyondCorp also uses an access proxy, so all applications are running through this proxy.

In addition, inventory-based access control is implemented to act as a trust reference and control engine to grant access to devices or users. The decision to granting access is gathered from various sources, and it can change over time. Furthermore, the authorization and authentication for using applications are based on a per-request basis. To ensure appropriate access, BeyondCorp considers the user's identity, group membership, and secure device.

3.2.2 NIST

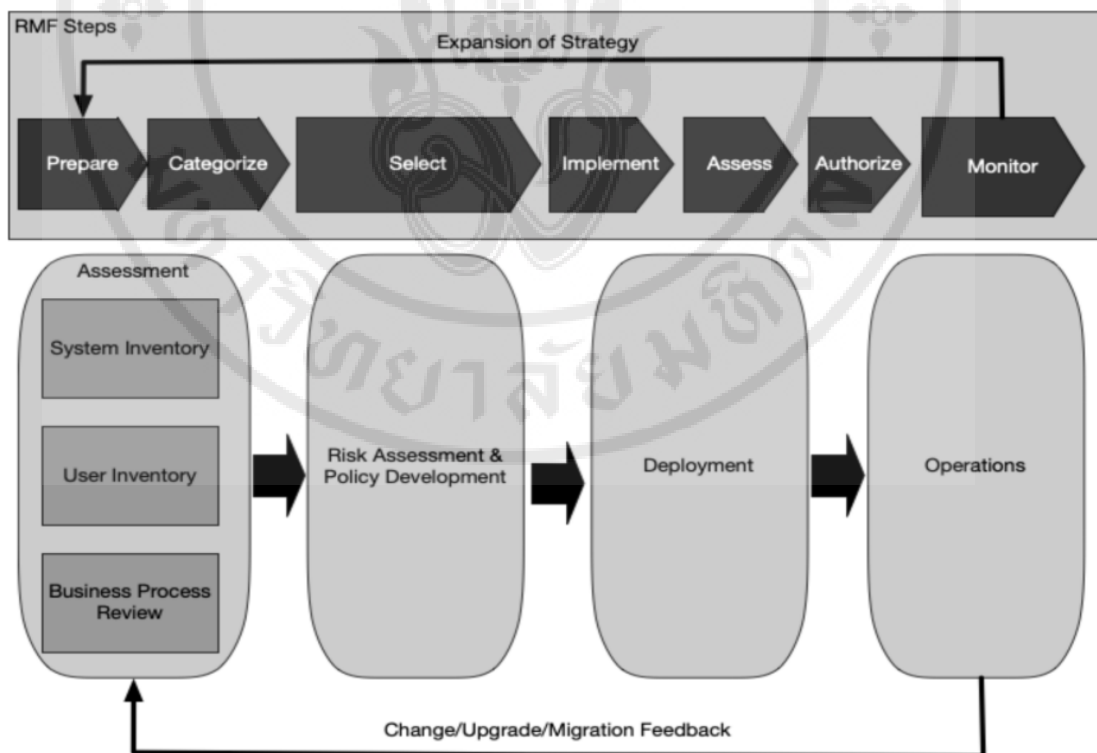


Figure 3.3: ZTA Deployment Cycle [13]

In 2020, a Zero Trust Architecture publication SP 800-207 was published by NIST [13]. It is stated that the initial stage of migrating to Zero Trust Architecture is to survey and identify data, assets, and subjects. Moreover, Data flows, and business

workflows across the enterprise are also needed to analyze. After identifying data and assets, the next step is to map these steps with a Risk Management framework.

After The initial phase of deployment can begin once the enterprise identifies a candidate workflow and relevant component of ZTA. Furthermore, the administrators must establish zero-trust policies by utilizing ZTA components to design appropriate policies. The enterprise must deploy the migration in monitoring mode. Once the enterprise gains more confidence regarding the migration, the next phase of ZT deployment can begin and extend ZTA across the enterprise.

3.2.3 Microsoft

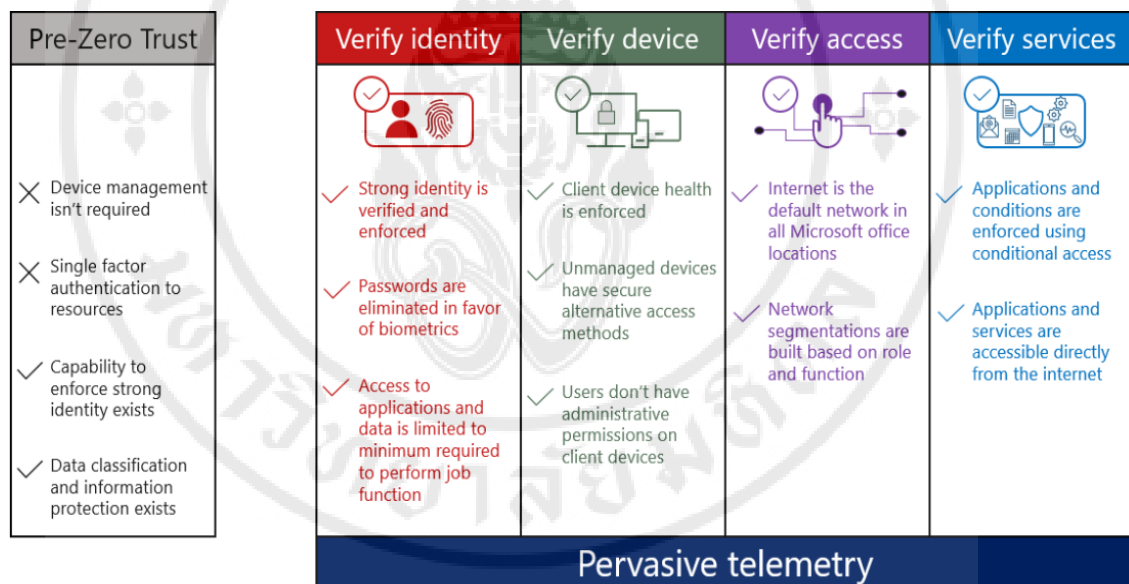


Figure 3.4: The Zero Trust Pillars [20]

In 2021, Microsoft provides an actionable best practices framework for Zero Trust adoption. This framework involves three steps, namely Planning, Implementing, and Measurement [18]. Firstly, Microsoft defines the vision, goals, and outcomes of Zero Trust adoption for the planning stage. Concerning the implementation stage, the structure of the Zero Trust program should align with business goals.

Furthermore, a short-term plan of Zero Trust adoption should be developed to a long-term roadmap. In the measurement stage, the organization adopting Zero Trust can measure business enable by assessing a number of security interruptions and deployment milestones. Moreover, security effectiveness can also be measured by

assessing a number of security incidents and tracking the improvement of security postures.

The original scope of Zero Trust implementation was limited to standard business services utilized across Microsoft's organization on services, such as Windows, macOS, Android, and iOS. Later, the scope was expanded to include all Microsoft apps. Additionally, device management solutions must be used to manage both corporate and personal devices that access the enterprise's resources.

The ZT pillar is divided into four major goals, according to Microsoft: verify identity, verify device, verify access, and verify service. For verifying identity, the MFA was implemented by using smart cards to manage privileged access to different servers. Then MFA usage is expanded to include all users that connect to enterprise resources from the outside.

To verify devices, the initial step is that all devices must be enrolled in a device management system. By using a device management system, it allows Microsoft to perform a device health check. This can ensure that the correct and secure devices are being used across the enterprise.

To verify access, micro-segmentation is applied to devices and users across the enterprise network. Microsoft mandated that their employees use the internet as their default network. When validating access, this network automatically routes users and devices to suitable network segments. In addition, they have set up a portal for registering devices. Microsoft allows users to identify, register, and manage devices. This portal helps ensure that employees are routed to the correct network.

To verify services, access to services and applications are restricted for verification. Microsoft modernizes legacy systems and applications to accomplish comprehensive conditional access validation or create solutions for apps that don't support conditional access systems natively.

3.2.4 Forrester

In 2021, Forester offers a practical method to implementing Zero Trust. The most significant aspect is to begin constructing a Zero Trust roadmap by measuring the maturity of an organization's state. The organization must then understand current business goals and security programs and document how existing solutions might be

reused. Then, the company should define a mutuality state and a timeline for achieving it. The key roadmap considerations for Zero Trust implementation comprises five main components: People, Workloads, Devices, Networks, and Data [21].

In the aspect of People, it is crucial to invest in identity solutions and authentication management technologies which address the most important business or audit issues regarding the People aspect. In addition, the enterprise should apply the least privilege mechanism for users to access data and applications.

As for Workloads, the enterprise should set up a solid cloud governance process and structure to guarantee that security and compliance are prioritized. The enterprise should also inventory and monitor workload configurations as the workloads can rapidly spread.

To manage devices, the company might use Zero Trust network segmentation, which helps to minimize cybersecurity risks. Moreover, before permitting BYOD to connect to the enterprise's network, devices must be hardened, and endpoint health checks must be performed.

To manage networks, the company must consider redefining the logical segmentation boundaries around network assets and enhancing segment isolation. In terms of data, the company should establish and understand what data needs to be safeguarded and how to protect that data. The company should look for technological solutions that can secure data in various situations.

3.3 ZT Migration Challenges

Moving to Zero Trust is not a simple system configuration. It requires migration strategy, proper plans, stakeholders' support and understanding the infrastructure requirements. Currently, there are many challenges and obstacles that hinder an enterprise to successfully adopt the ZTA model. The following challenges are common obstacles to ZTA migration.

Table 3.1: A List of ZT Migration Challenges

ZT Migration Challenges	
C1	Vendor Lock-in
C2	Lack of Industry Standard
C3	User Disruptions During Migration
C4	Legacy Systems
C5	ZTA Service Controls
C6	Integration Issues
C7	Zero Trust Policies
C8	Discovery Resources
C9	Political Resistance
C10	Regulatory Compliance
C11	Analysis Paralysis

1) Vendor Lock-in

This issue has previously occurred in other technologies, including IoT and cloud technology. For example, some cloud providers encourage new customers to join up their service with special deals and discourage users from switching to other cloud services. In addition, the cloud provider may deter the user from leaving by imposing legal limitations, technical barriers, or additional fees. Furthermore, it is found that many customers or businesses lack sufficient understanding about proprietary technologies that may cause interoperability constraints [4].

2) Lack of Industry Standard

Industry best practices act as leaders to utilize the principles of ZT. However, now there is no industry standard providing concrete guidance regarding a proper plan for implementing ZTA in the enterprise. As a result, it is currently difficult

for an enterprise to fully understand whether ZT implementation has been succeeded [3]. Moreover, some components in the ZT platform require standardization. For instance, the policy decision point (PDP) involves receiving and exchanging data from many sources. However, there is a lack of common standards for exchanging information in this system [4].

3) User Disruptions During Migration

The issue of user disruptions may occur during each migration phase. The ZTA approach is implementing and replacing the users from the old system during the migration process. This new approach is encouraging and shifting users to the new IT environment [4]. However, the enterprise may experience some technical issues and need to provide remediations to users when migrating users to the new systems.

4) Legacy Systems

Legacy systems, applications, and infrastructure have been operated for many years. The concepts of ZT or the least privilege might not align with how these legacy systems currently function. Migrating to ZTA can cause some issues or defects to the old systems. Consequently, it can create a bubble where more resources must be carefully managed than the original implementation plan. In addition, there are some systems or applications that an enterprise develops on its own [22]. If these systems may have to be redesigned or redeployed to support ZTA, it may be costly and requires more resources to accommodate these transitioning.

5) ZTA Service Controls

The ZT platform requires precisely and intelligently supported systems to make the appropriate decision when granting access to users. These systems involve trust level, trust algorithm, and resource classification. Determining an appropriate level of trust can be a challenge for an enterprise. It is essential to ensure a level of trust is not too high because it may cause users difficulties when attempting to access services. Similarly, a level of trust should not be too low; otherwise, it can be less secure. In addition, the information and parameters feeding to the trust algorithm (TA) come from many sources and services. Currently, there are no reliable techniques

to weigh those parameters. Therefore, an enterprise needs to carefully and continuously monitor and update these parameters to guarantee its proper operations [4].

6) Integration Issues

Migrating to ZTA is not a simple adjustment and configuration. First, an enterprise needs to understand infrastructure requirements and ZT-supported systems to support security functions. As the ZT platform may comprise many services across multiple providers, making them serve as a single control pane may be difficult and cause integration concerns [5].

7) Zero Trust Policies

Creating ZT policies is one of the common challenges when migrating to ZTA. As the ZT platform requires appropriate policies to enforce a fine-grained approach for security controls, it can be difficult for an enterprise to create correct, consistent and comprehensive policies to support ZT decisions. Another issue relating to ZT policies is that these policies need to be up-to-date for the changes regarding protected resources, contexts, and access requirements. Creating and managing ZT policies to adapt with those changes are challenging, especially when there are time constraints [23].

8) Discovery of Resources

In a large or complex enterprise, getting accurate view of all resources can be difficult and challenging, particularly when those environments have poor monitoring or growing quickly. To discover all resources to serve a fine-grained approach, it requires time and effort to collect and analyze these data. Moreover, the issue of unmanaged devices like BYOD can also cause difficulty when performing discovery as the enterprise may not have fully control over those devices [4]. Therefore, migrating to ZTA may take more time if resource discovery has not been conducting efficiently [24].

9) Political Resistance

When introducing new technologies or systems in an enterprise, the implementation team may experience political resistance to change. This situation concerns people imposing barriers to change or ignorance. The reasons for resistance

include organizational culture and technical bias in security tools or architecture. Hence, the migration team should consider managing and handling resistance from people in the organization when migrating to ZTA [24].

10) Regulatory Compliance

Many enterprises are regulated by government or industry regulations. As a result, some data or systems must comply with regulatory requirements. However, those regulators may lag behind new technology solutions. This issue may cause difficulty for enterprises to adopt new and modern technologies to meet regulatory requirements [24].

11) Analysis Paralysis

Before migrating to ZTA, an enterprise should clearly and fully understand the new technology, identify scope or understand risks that may delay action or decision. In addition, it is essential to gain approval from many stakeholders before deploying the ZTA migration. Finally, it can be challenging when the migration team must carefully consider the operational maturity and integration with other existing systems that can provide the same functions [24].

CHAPTER IV

RESEARCH METHODOLOGY

This chapter describes the development of a proposed ZTA migration framework. Firstly, we explain how we conducted a systematic review to obtain the literature for this study. Secondly, we illustrate a framework design methodology describing a process to develop a proposed ZTA migration framework. Thirdly, we describe the findings that can use to improve the proposed ZTA migration framework.

4.1 A Systematic Review (PRISMA)

This study is conducted by using a systematic review by following the PRISMA method (The Preferred Reporting Items for Systematic reviews and Meta-Analyses). The PRISMA provides a transparent method for reviewers to identify, select and synthesize studies [25]. Hence, we used PRISMA to perform a literature search and identify review papers and relevant reports on the ZTA migration.

The literature search was conducted in two parts. Firstly, we conducted a literature review by searching and selecting academic peer-reviewed literature such as journals and conferences papers. Secondly, we use a web search to find and select literature from credible expert sources such as government reports, white papers, Zero Trust provider reports.

We identified and recorded information to an MS Excel spreadsheet such as title, abstract, authors' names, journal name, published organization, and year of publication to record the studies. We then recorded the identification of studies used in this study by adding information to the PRISMA flowchart, as shown in figure 4.1.

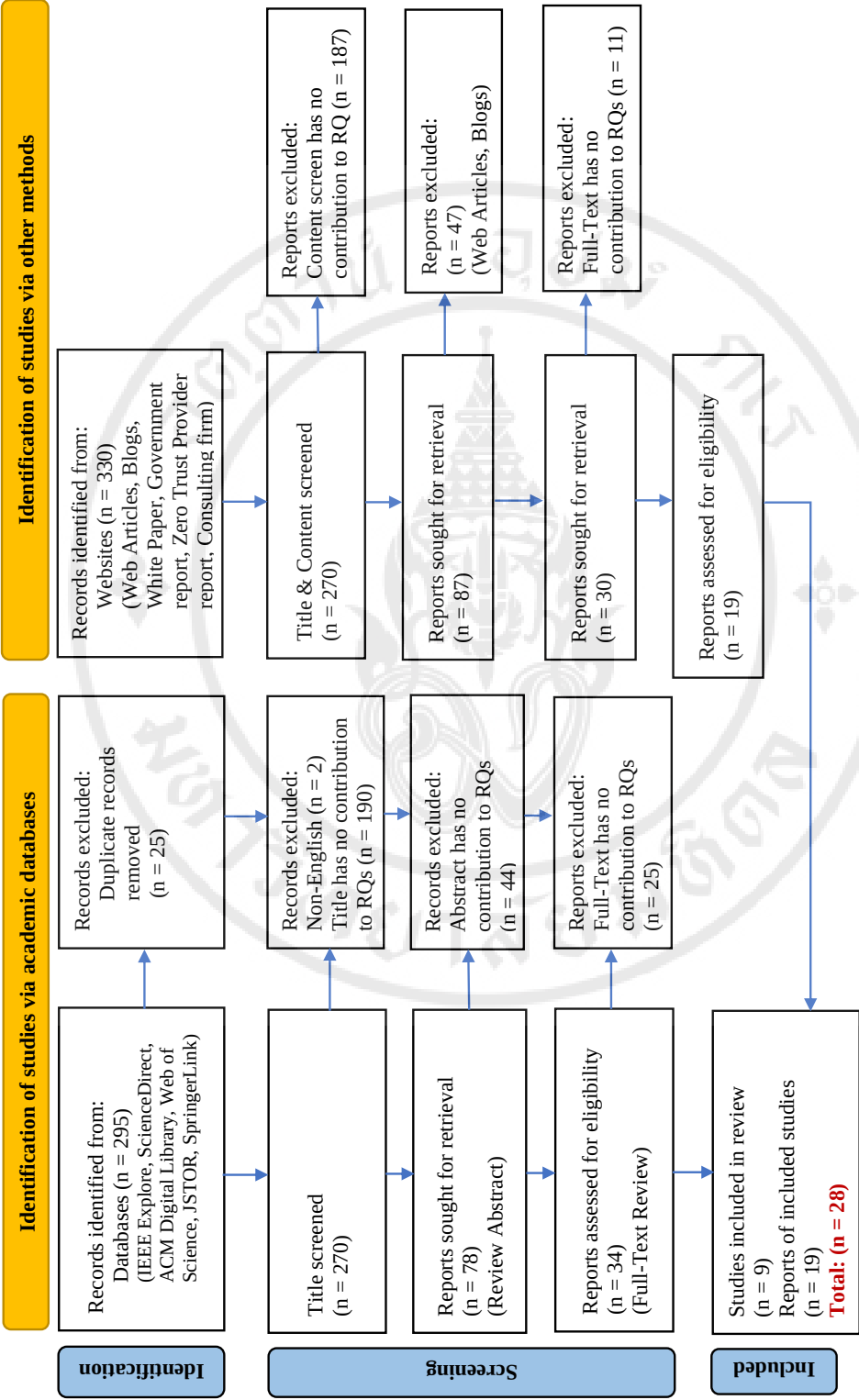


Figure 4.1: The PRISMA flowchart showing the process of how we select and obtain the literature for our study [25].

4.1.1 Identification of studies via academic database

To search for academic literature, we specified the keywords “Zero Trust” and “Zero-Trust” as the terms for searching. Next, we applied the search string to six well-known academic databases, namely ScienceDirect, ACM Digital Library, IEEE Explore, Web of Science, JSTOR and SpringerLink. Then, we reviewed the title of the academic literature found in the databases most relevant to zero trust concepts and found 295 studies that could perform a further screen for the review.

We then excluded articles that have duplications with other databases. Moreover, the screen a title and excluded the articles not written in English and a title that was not relevant to ZTA migration. After that, we reviewed an abstract of 78 articles and found that 44 articles did not have a contribution to our studies. In the next stage, we performed a full-text review of 34 articles. The studies that are not relevant to our research questions were excluded. Finally, we found 9 studies contributing to our research questions included in our study.

4.1.2 Identification of studies via other methods

To search for other studies from the web search, we defined the keywords as “Zero Trust Migration”, “Zero Trust Implementation,” and “Zero Trust Migration white paper”. We followed the guidelines to include the grey literature present by Garousi V., et al. [26] to include the gray literature in our study. These guidelines provide helpful process to include grey literature such as white papers, reports and ensure high quality of selected grey literature.

We applied our search terms in Google Search Engine to perform the grey literature search. The scope of our google search is limited to 10 pages of the search results for each search string, and we found 330 relevant grey literature to perform the further screen. First, we checked the title and skimmed through the content from the search; we then excluded 187 reports which are not qualified to obtain for further screening.

Next, we reviewed 87 reports and excluded 47 web articles and blogs as they do not provide insightful ZTA migration information. Later, we reviewed 30 reports and excluded 11 studies as their information did not contribute to our research questions.

Finally, we obtained 19 high-quality reports for our analysis, such as government reports and white papers from ZT vendors and consulting firms.

4.2 Framework Design Methodology

In this study, we established a framework design methodology as a process to develop a comprehensive ZTA migration framework. The output of each step aims to analyze and improve the ZTA migration processes, as shown in figure 4.2.

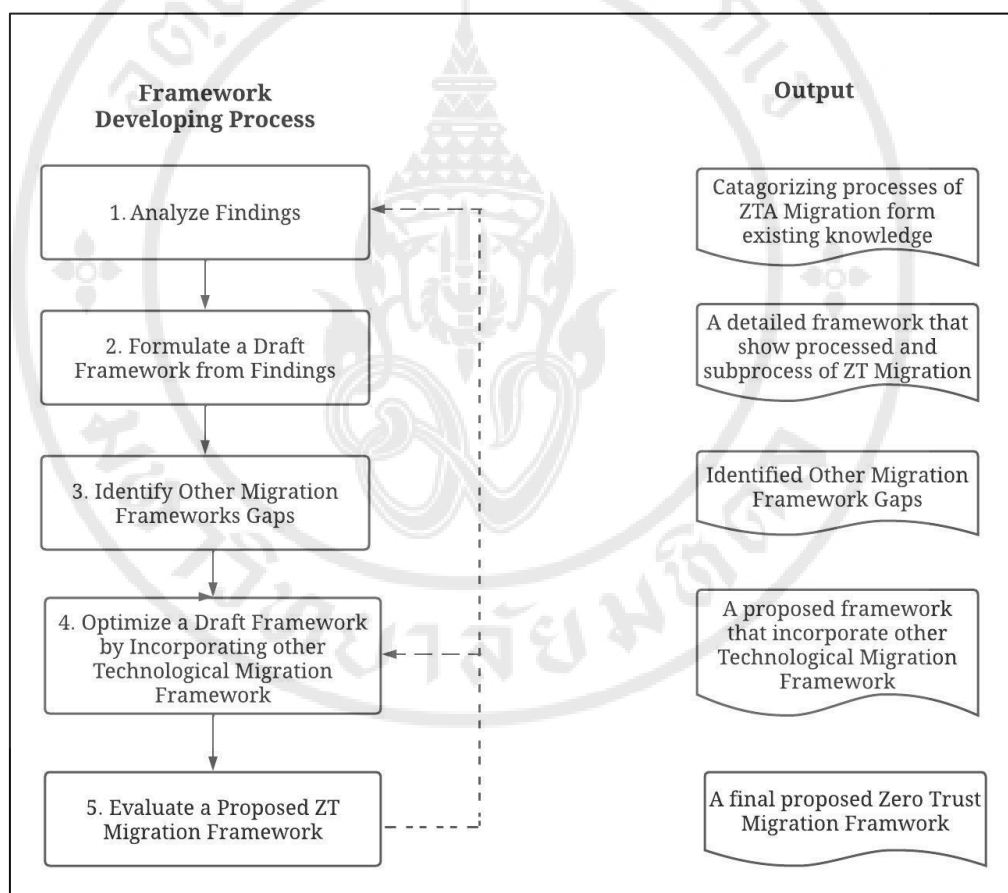


Figure 4.2: A Framework Design Methodology

This methodology comprises of five steps as described as follows.

- **Step 1– Analyze Findings**

We analyzed existing studies and knowledge regarding ZTA migration methods and techniques obtained from a systematic review. The output of this

step is to gain an overview of ZTA migration process and form the analysis into rough ZTA migration processes.

- **Step 2 – Formulate a Draft Framework from Findings**

In this step, we thoroughly analyzed existing ZTA migration studies to gain more details regarding methods and techniques of the migration. We then categorized the findings into a draft framework forming main processes as the output of this step.

- **Step 3 – Identify Other Migration Framework Gaps**

This step is to identify the gaps from other studies and determine what other frameworks are lacking in their migration processes, as shown in Table 4.3. The ZTA-related migration studies are given framework code and evaluate their studies against main processes defined in step 2, as shown in Appendix B.

- **Step 4 – Optimize a Draft Framework**

This step is to take consideration and learn from other technological frameworks such as cloud migration, legacy system migration, DevOps and etc. The aim of understanding other technological frameworks may help improve a draft ZTA migration framework to be more efficient. In this study, we utilize the DevOps methodology to optimize the proposed framework.

- **Step 5 – Evaluate a Proposed ZTA Migration Framework**

We developed evaluation criteria to evaluate a proposed migration framework for its usability and effectiveness. The evaluation criteria comprise generic criteria and ZTA-specific criteria. This evaluation framework is also used to evaluate other ZTA migration frameworks that we obtained for our analysis to understand the quality and effectiveness of each framework.

4.2.1 Analyze Findings

We analyzed existing studies and knowledge of ZTA migration (See Appendix B). Then we outlined the finding into rough 6 processes of ZTA migration. This is a big picture of ZTA migration processes, as described in table 4.1.

Table 4.1: Process Description of Each ZTA Migration Process

Process	Description
1. Strategize Zero Trust	The first process of ZTA migration is have strategy to migrate to ZTA and gain stakeholders' support, especially the top management. Then the enterprise should establish a Zero Trust vision and goals of having ZTA.
2. Context Assessment	This process establishes the ZTA migration plan as a master plan for migration. First, an enterprise needs to discover data, assets and applications owned by the enterprise. Then those data and assets should be mapped to understand data flows and processes. This will help improve the visibility of assets and flows across the enterprise. Finally, the enterprise needs to understand the baseline architecture and set the target architecture.
3. Architect ZTA	In this process, an enterprise establishes the ZTA migration plan as a master plan for migration. In addition, the enterprise needs to understand the baseline architecture and set the target architecture. The enterprise should also consider on preparation of device, user and network.
4. Zero Trust Transformations	This process concerns establishing ZTA migration methods and implement them from a pilot project to full production of the migration.
5. Monitoring and Maintenance	This process involves monitoring and maintaining the ZTA ecosystem to gain network and user activities visibility.

	Moreover, an enterprise should provide education and training for IT staff and provide user support.
6. Optimize ZTA Security	This process involves upgrading ZT performance and its capabilities. It will help utilize ZTA security in more automation and orchestration manners.

4.2.2 Formulate a Draft Framework

After analyzed existing studies and knowledge of ZTA migration from Step 1, We then Then we drafted and illustrated the finding into processes of ZTA migration, as shown in figure 4.3.

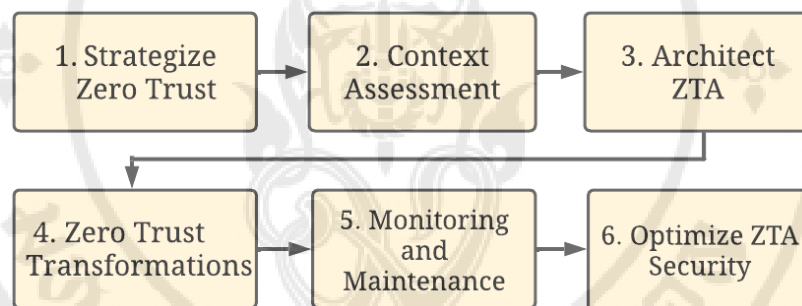


Figure 4.3: An Overview of ZTA Migration Process

4.2.3 Identify Challenges and Other Migrations Framework Gaps

We identified and summarized eleven challenges of ZTA migration, as shown in table 4.2. In addition, we analyzed the ZTA migration methods of other studies. Also, we identified the gaps in other ZTA migration frameworks, as illustrated in table 4.3. We also addressed the findings from our analysis to justify and overcome those challenges, as depicted in table 4.4.

Table 4.2: ZT Migration Challenges

ZT Migration Challenges	
C1	Vendor Lock-in This issue may occur when customers have insufficient knowledge about proprietary technology. As a result, the vendors may try to discourage users from switching to other services.
C2	Lack of Industry Standard Currently, no industry standard can provide a guideline on applying and implementing ZT concepts in an enterprise.
C3	User Disruptions During Migration During the migration process, there might be issues of user interruptions. The enterprise should have plans or methods to remedy user interruption.
C4	Legacy Systems An enterprise needs to be aware of old IT infrastructures such as legacy systems and applications. It may not be easy to migrate to ZTA as the old systems might need to be redesigned or redeployed.
C5	ZTA Service Controls The ZT platform comprises intelligent systems. These systems require information from several sources to determine and grant access to users. However, it is challenging to have reliable techniques to set the appropriate weight to many parameters to feed information.
C6	Integration Issues The ZT platform is composed of many tools and services from several vendors. Therefore, it may cause difficulty when an enterprise needs to combine those services as a single control pane.
C7	Zero Trust Policies

	Establishing appropriate ZT policies is challenging. This is because an enterprise needs to ensure that those policies are adaptive and up-to-date for the changing context.
C8	Discovery Resources In a large enterprise, discovering all resources is challenging. Moreover, these tasks require time to analyze information to get an accurate view of resource visibilities.
C9	Political Resistance There might be people who resist changing to new systems and technologies. This issue may cause the ZTA migration to be delayed.
C10	Regulatory Compliance New technologies may have issues with regulatory compliance as the regulators or auditors may not be aware or have insufficient knowledge to understand the impacts of modern technologies.
C11	Analysis Paralysis Having a complete understanding of ZTA can be challenging. It requires time, knowledge and resources. The migration team needs to ensure whether the existing solutions that an enterprise currently has can provide similar functions as ZTA or not.

Table 4.3: Identification of gaps showing what is lacking in other frameworks

Framework Code	Strategize Zero Trust	Context Assessment	Architect ZTA	Zero Trust Transformations	Monitoring and Maintenance	Optimize ZTA Security
[A1]		✓			✓	
[A2]		✓	✓			
[A3]		✓				
[A4]				✓		
[A5]		✓				
[A6]			✓			
[A7]	✓					
[A8]	✓	✓		✓		
[A9]		✓	✓		✓	✓
[A10]	✓	✓	✓	✓		
[A11]	✓		✓	✓		
[A12]	✓	✓	✓		✓	
[A13]	✓		✓			✓
[A14]	✓	✓	✓	✓	✓	✓
[A15]		✓	✓		✓	✓
[A16]	✓	✓	✓			
[A17]			✓			
[A18]		✓		✓		✓
[A19]	✓		✓	✓		
[A20]	✓		✓			
[A21]			✓		✓	

As is observed, several studies focus on strategize, context assessment, and architect ZTA processes. These processes are essential as many enterprises must have strategies to implement ZTA in their enterprises' context. Furthermore, they need to know the current state and gain resource visibility before migrating to ZTA. In addition, the enterprises should thoughtfully design and architect ZTA. This process can help the enterprise design suitable implementation plans for the target architecture.

Moreover, many studies emphasize zero trust transformation process. For example, the studies of K.D. Uttecht (2020) [5] and BeyondCorp (2014) [16] utilize a low-risk migration strategy for migration. In addition, the study by D. Tyler and T. Viana (2021) explains technical concepts on implementing ZTA such as implementing micro-segmentation and applying access controls.

It can be seen that the process of monitoring and maintenance, and optimize ZTA are not the main focus points of many studies. However, to successfully migrate to ZTA, the enterprise should understand comprehensive migration processes.

Based on the challenges of ZTA migration and the gaps defined in other ZTA frameworks, we identify our findings and provide recommendations and justification to overcome those challenges and gaps, as shown below. These recommendations will be applied to our draft ZTA migration framework to improve and adjust it appropriately.

Table 4.4: Identify findings to address and overcome ZTA migration challenges.

Finding 1 Political Resistance (C9)	One of identified challenges for migrating to ZTA is political resistance. There might be some people resist to change to new technologies and solutions due to culture, bias, or personal issues.
Recommendation 1	It is recommended to incorporate a change management plan and strategy to handle political resistance in an enterprise. To harness political resistance, an enterprise should try to get consensus on the core problem and ensure that negative impacts have been manage appropriately [27]. Furthermore, it is recommended to establish a project champion to communicate and empower users to reduce barriers. The techniques that can be adopted to communicate include in-person or town hall meeting, email, newsletter, or videos and blogs [28].
Finding 2 Create ZT Policies (C7)	Another challenge when migrating to ZTA is creating ZT policies. ZTA requires fine-grained policies that can be adaptive and intelligent. It is challenging as the policies should be up-to-date and quickly adjust for the changes.
Recommendation 2	When creating ZT policies, an enterprise needs to consider these 4 factors, namely correctness, consistency, minimality and completeness [23].

	▪ Correctness: ZT policies need to achieve stated objectives. The correctness of the policies should be checked against semantic attributes and related applications. ▪ Consistency: An enterprise validates policies to ensure those policies do not include both permission and a denial for the same subject, activity or protected resource. ▪ Minimality: It is to ensure that ZT policies do not have duplications and redundancy. This issue will increase more tasks to manage these policies. ▪ Completeness: It requires that each action carried out by the subjects should be accompanied by a policy that govern such request. Otherwise, the default decision will normally refuse the request.
Finding 3 Vendor Lock-in (C1)	This challenge occurs when the technology service vendors try to impose customers to switch to other service providers. This is because some customers lack sufficient knowledge regarding proprietary technology. The issues to discourage users from changing to other services can be technical barriers, legal limitations, or additional fees.
Recommendation 3	It is recommended to have a complete understanding of the technical requirements of ZTA in the enterprise context before buying ZT solutions from the vendors. In addition, the enterprise should consider software interoperability to prevent the vendor lock-in issues. When this issue occurs, the enterprise may consider signature adaptation to solve signature mismatch. Additionally, the mismatch in the granularity of interaction messages can be resolved by behavioral adaptation. Service adaptation like QoS (quality

	of service or SLA negotiation) is also essential to prevent the vendor lock-in issues [29].
Finding 4 Legacy Systems and Integration Issues (C4, C6)	As legacy systems have been operating for many years, a new security approach like ZTA may not be compatible with these legacy systems. In addition, migrating to ZTA may also cause problems for these existing systems. Consequently, the enterprises may require more resources and time to implement ZTA with these legacy systems. Furthermore, migrating to ZTA can cause integration concerns as it comprises many systems and services to provide ZT security.
Recommendation 4	It is recommended that the IT and the migration teams have an appropriate plan to evaluate the existing legacy systems and whether they can integrate and work well in the ZT environment. For outdated legacy systems that cause many problems like security and productivity issues, these systems should be upgraded or retired in consideration of cost-effective investment. To manage integration issues, the enterprise should have a project plan for system integration. Moreover, the enterprise should review in-house resources with the necessary skills and knowledge and determine whether outside staff should be hired. In addition, the enterprise should find a vendor with expertise in system integration knowledge. Finally, the integration project should be carefully monitored and communicated to relevant stakeholders.
Finding 5 Analysis Paralysis (C11)	This challenge occurs when the enterprise does not have a clear and complete understanding of the new technology. As a result, it will be challenging to consider how it can be effectively utilized in the enterprise context. Identification of scope and risks can also delay action and decision to adopt ZTA. Moreover, evaluating existing systems to integrate

	with the new ZT systems can also cause challenges to the migration team.
Recommendation 5	It is recommended that the migration team cooperate with key stakeholders early to initiate the ZT project and get approval. Then the migration team can start the ZT pilot project as soon as possible, even if there is an initial limitation of scope. In addition, the ZT pilot project can motivate other terms to understand and accept the change [24].
Finding 6 Regulatory Compliance, Lack of Industry Standard (C10, C2)	Many enterprises are enforced to comply with government or industry-issued regulations such as data sets or systems. However, these regulations may lag behind new technologies. Consequently, it can cause difficulty for the enterprises that want to adopt new technology and meet the regulatory requirements. Furthermore, currently, no industry standard offers guidance or best practices to implement ZTA in enterprises appropriately. Therefore, the enterprises may find it difficult to fully understand how to implement ZT in their organizational context successfully. Furthermore, the ZT platform also requires standardization for exchanging information across systems.
Recommendation 6	It is recommended to proactively engage with stakeholders early, such as governmental regulators, external auditors, or relevant third parties. For example, many enterprises are members of associations related to their businesses and services. The working groups in a particular association may raise concerns about adopting new Zero Trust systems and the need to have industry-standard for ZTA to government regulators to establish standards or regulations for implementing ZTA in the enterprise. In addition, now many

	enterprises have successfully implemented ZTA. Therefore, other enterprises may learn about the implementation of ZTA from the success cases.
Finding 7 Discovery Resources (C8)	Discovering and having accurate views of all resources in the enterprise can be tricky and challenging. Moreover, collecting and analyzing data requires time and effort to discover all resources. In addition, many enterprises allow unmanaged devices to be used by employees. This issue can make it more difficult for the enterprise to discover resources and control these devices completely.
Recommendation 7	It is recommended to choose how to deploy the ZT platform. The enterprise should understand that having complete visibility of every data flow is unnecessary before beginning the ZT implementation. Furthermore, the enterprise may consider using an observational approach to gather and analyze the data network to ensure that the system does not interrupt user productivity. Another approach is an incremental approach that enrolls and onboarding groups of users incrementally [24].
Finding 8 User Disruptions during Migration (C3)	This challenge may occur during the migration process, especially when shifting and migrating users from the old systems to the new IT environment. In addition, the enterprise may encounter a particular technical challenge that needs to provide user support for the migration.
Recommendation 8	It is recommended to have a remediation service to support users when there is a service interruption that may impact user productivity. It is crucial to communicate with users whom the migration might impact. In addition, the enterprise can establish a service for the user to perform self-

	remediation for common problems to reduce the IT workload on troubleshooting [30].
Finding 9 ZTA Service Controls (C5)	As the ZT platform will provide an appropriate decision for granting user access, this platform comprises accurately and intelligently supported systems. However, determining the appropriate trust given to users can be challenging. Currently, there are no reliable methods for weighing the trust algorithm (TA).
Recommendation 9	It is recommended that the trust algorithm should be contextual as it can help mitigate threats, especially insider attacks. For instance, an HR officer who usually accesses the HR system during normal working hours is currently attempting to do so after hours. Consequently, the contextual TA can effectively detect and trigger an alert to this new behavior. However, it is crucial to find the balance between security, usability, and cost-effectiveness [13].

4.2.4 Optimize a Draft Framework by Incorporating Other Technological Migration Framework

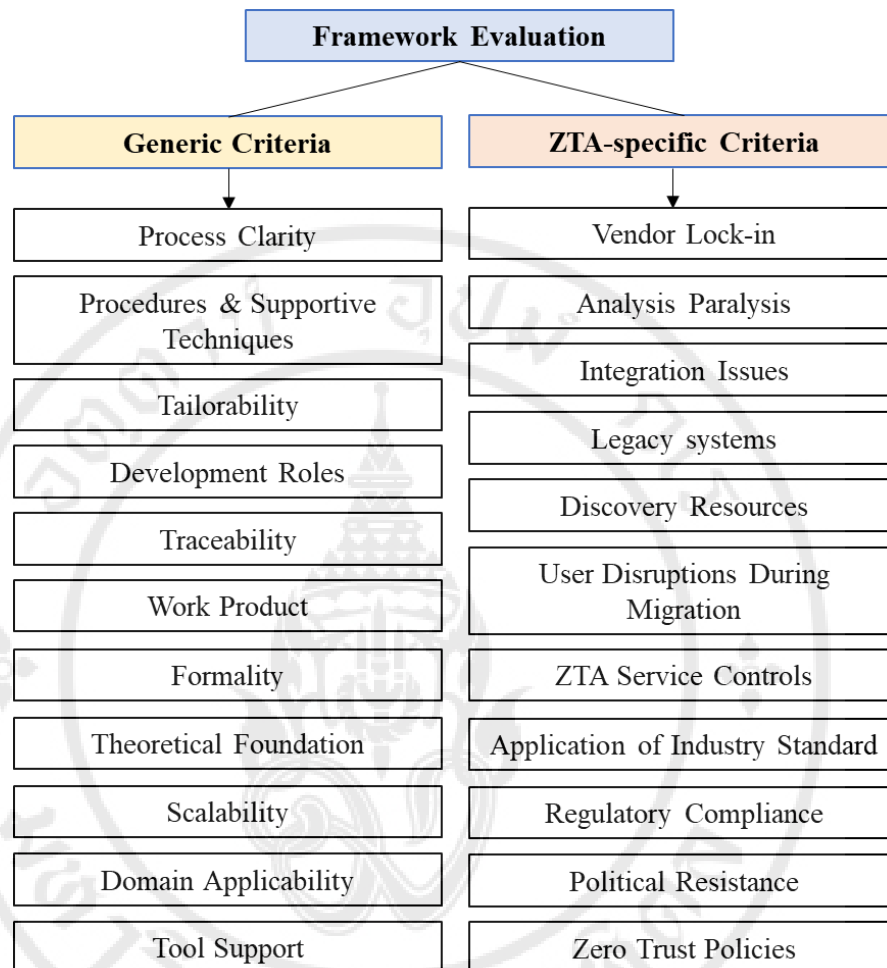
We plan to optimize a draft ZTA migration framework by considering other technological migration frameworks, including cloud migration, legacy system migration, and DevOps methodology. Cloud migration and Legacy system migration have been scholarly studied and extensively researched in the academic field for many years. Moreover, DevOps is a software development approach which considers the development and operations of the entire service delivery lifecycle. In this study, we utilize DevOps methodology to optimize a draft ZTA migration framework as it provides insightful practices and shares similar migration methods for the whole lifecycle.

4.2.5 Evaluate a Proposed ZT Migration Framework

We developed an evaluation framework as criteria to evaluate a proposed ZTA migration framework. This evaluation framework will help ensure the quality, usability, and effectiveness of a proposed ZTA migration framework.

As for generic criteria for evaluation, we applied the evaluation framework of the cloud migration process conducted by the study of Fahmideh, M. et al. [31]. The generic evaluation criteria were well defined as these criteria are synthesized by several existing frameworks regarding software engineering. For example, the process clarity criterion ensures that a proposed ZTA migration framework can clearly describe suggested processes. As for the theoretical foundation, it is to be evaluated that the proposed framework has been developed based on the existing software engineering practices.

For ZTA-specific criteria, we utilized the challenges of migrating to ZTA identified by our analysis as criteria to evaluate other studies and our proposed ZTA migration framework. The considerations of ZTA migration challenges as criteria of evaluation help assess whether the ZTA migration frameworks can address or consider the migration challenges in their practices.

**Figure 4.4:** Evaluation Framework

CHAPTER V

A PROPOSED ZTA MIGRATION FRAMEWORK

This chapter describes the proposed ZTA migration framework that considers incorporating DevOps methodology to enhance the effectiveness of the ZTA migration. In addition, this chapter provides six main processes and associated sub-processes of the ZTA migration framework that an enterprise planning to migrate to ZTA can utilize this framework for the migration.

5.1 Incorporating DevOps Methodology

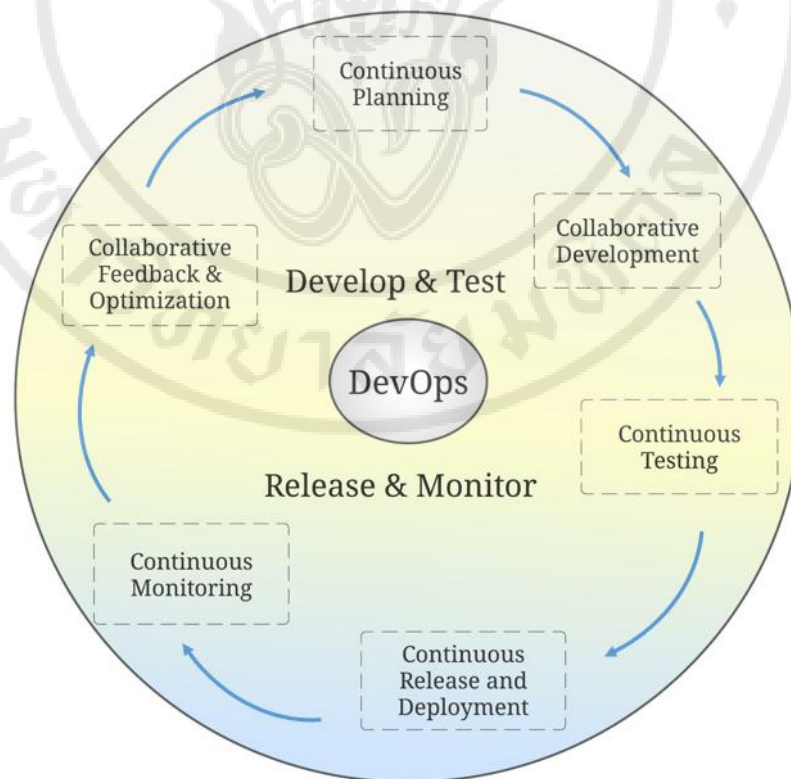


Figure 5.1: DevOps Cycle

DevOps is a software development methodology emphasizing communication, collaboration, and continuous development and integration. DevOps

aims to provide software quality assurance throughout the entire lifecycle. Additionally, it seeks to eliminate the discrepancy between development and operation with agile software development [32], [33]. DevOps can assist a business in achieving high service quality and performance stability as it can receive quick customer feedback [32].

DevOps emphasizes the software development and operation lifecycle, as illustrated in figure 5.1. In addition, it also considers continuous planning, continuous deployment and delivery, and continuous assessment and feedback as the key component of the DevOps lifecycle [34]. Furthermore, an enterprise should maintain continuous operation to handle disrupting end users during software and hardware updates [32]-[34].

From our perspective, the DevOps principles and methodology can efficiently be applied to improve the ZTA migration as it shares similar aspects of technology development and migration cycle. For instance, a high collaboration of key stakeholders is required for the ZTA migration. Additionally, the ZTA migration projects are carried out iteratively and are expanded to the next stages when efficient migration techniques have been established through monitoring and feedback. Therefore, integrating DevOps concepts with the ZTA migration framework can improve effectiveness and provide value throughout the migration process.

5.2 A Proposed Comprehensive ZTA Migration Framework

In this section, we propose a comprehensive framework for migrating to ZTA based on the results of the quality analysis and synthesis of our obtained studies. This framework illustrates the main processes and related sub-processes in migrating to ZTA. As depicted in figures 4.7 and 4.8, it consists of the following six main processes: strategize Zero Trust, context assessment, architect ZTA, Zero Trust transformation, monitoring, and maintenance, and optimize ZTA security, as shown in 4.7 and 4.8.

A comprehensive framework for migrating to ZTA integrates the concepts of DevOps methodology to ensure quality-of-service delivery. Moreover, this framework also considers the zero-trust ecosystem, including visibility, analytics, automation, and orchestration. In addition, when migrating to ZTA, it is essential to ensure compliance with best practices and standards. There are six processes, and their corresponding sub-processes.

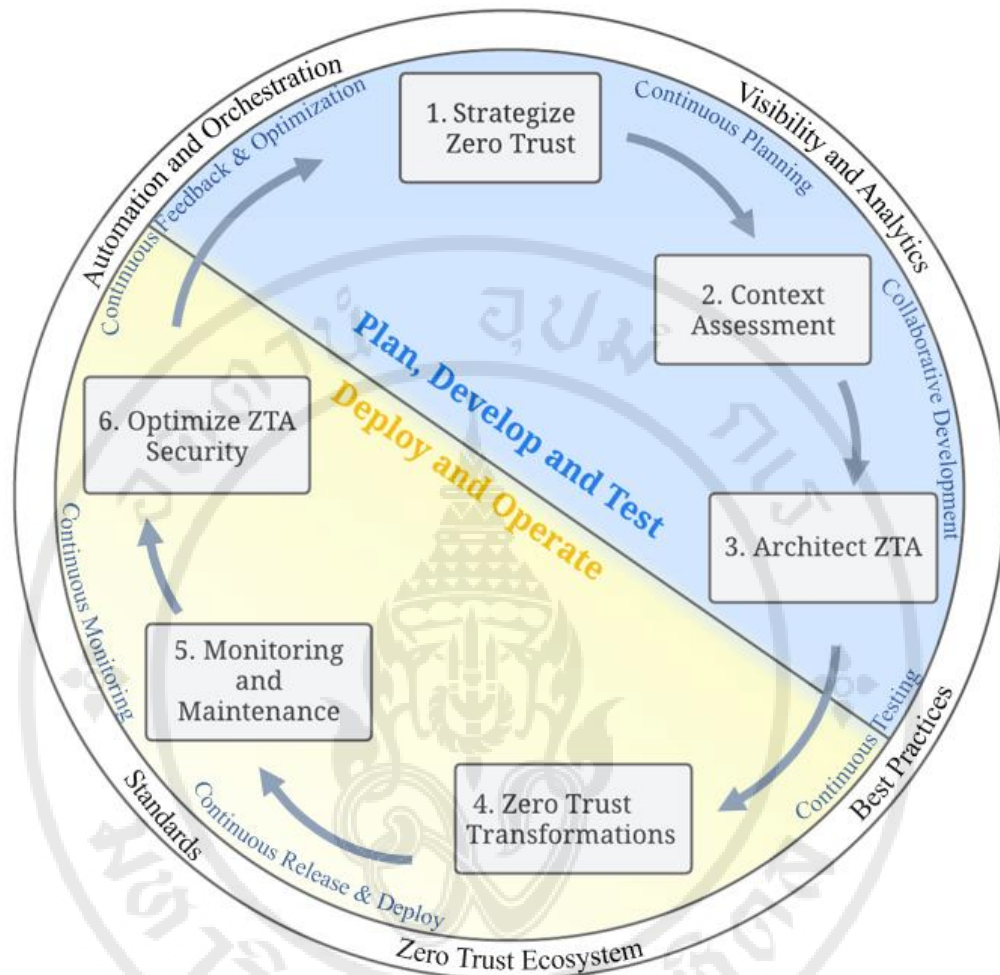


Figure 5.2: A Proposed Comprehensive Framework for Migrating to ZTA

1. Strategize Zero Trust	2. Context Assessment	3. Architect ZTA	4. Zero Trust Transformation	5. Monitoring & Maintenance	6. Optimize ZTA Security
- Create Zero Trust Strategy - Set up Zero Trust Teams	- Assess the Current States - Perform Resource Discovery	- Create a ZT Migration Plan - Preparation of Device, User and Network - Design Zero Trust Policies	- A Pilot Program to A Full Production Method - Measure Implementation Success & Error Remediation	- Monitor ZT Ecosystem - Measure Security Effectiveness	- Zero Trust Performance Upgrade Plan - Adoption of Securities Automation and Orchestration

Figure 5.3: The main processes and sub-processes of ZTA migration

5.2.1 Process I – Strategize Zero Trust

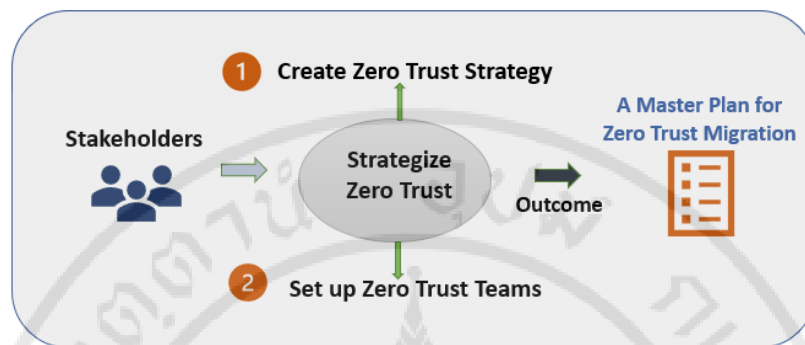


Figure 5.4: Process I – Strategize Zero Trust

The first step to ZTA is strategizing ZTA principles and concepts in an enterprise. Developing zero-trust strategies and getting support from key stakeholders is crucial. As shown in figure 5.4, the outcome of this process is a master plan for ZTA migration. This plan will serve as a blueprint for stakeholders to define what they want for ZTA migration.

1) Create Zero Trust Strategy

The primary step in the migration to ZTA is to define a vision and gain buy-in from leadership and stakeholders [21], [35], [36]. All parties involved in the ZTA migration projects must recognize the importance of this implementation, such as improving business agility and enhancing security controls [37]. Furthermore, an enterprise should proactively engage with external stakeholders early to ensure they understand the needs and stay caught up to new technologies. The external stakeholders include governmental regulators, external auditors, or relevant third parties.

An enterprise must also develop a master or strategic plan for the ZTA migration. This plan will help the enterprise understand the scope, capabilities, and implementation environment [3], [38]. The ZT pilot project should begin as soon as possible, even if the initial scope is limited. This is because it can help an enterprise define what they want and available Zero Trust solutions early [24].

2) Set Up Zero Trust Teams

Zero Trust teams are crucial for the smooth transition and the success of the Zero Trust implementation projects. The teams should be cross-functional teams of business and IT decision-makers [38], [39]. The team can be formed into two groups:

The first group serves as the project's key decision makers, providing project direction and reviewing the projects [24]. The examples of the group of key decision-makers are as follows.

Governance Board: Providing direction and making decisions regarding new initiatives and technologies.

Architecture Review Board: The main duties are to review current technologies and define the enterprise architecture.

Change Management Board: The primary responsibility is to promote Zero Trust solutions in a production environment.

The second group is a Zero Trust implementation team. The team members should be appropriately chosen to ensure they are associated with these security functions, including data, application, user, device, network and infrastructure [13], [39], [40].

In addition, an enterprise should communicate the transition to ZTA with users. This is because inefficient communication results in user confusion and migration disruptions. Furthermore, an enterprise should establish a communication plan or campaign to promote the ZTA migration projects. It can help raise awareness and increase user buy-in early [41][42].

5.2.2 Process II – Context Assessment

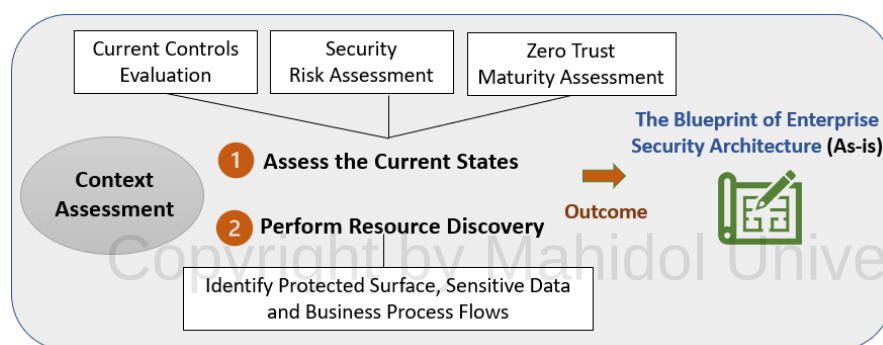


Figure 5.5: Process II – Context Assessment

The second process is to perform a context assessment, as depicted in figure 5.5. This process helps an enterprise understand the current state of enterprise's security. To have accurate views of enterprise's resources, the enterprise must perform resource discovery. The outcome of this process is the blueprint of enterprise security architecture. This blueprint acts as the security baseline for determining the current and desired state of Zero Trust maturity.

1) Assess the Current States

This sub-process is essential for an enterprise to understand and have an overall picture of an enterprise's security state. This sub-process is composed of three main methods: 1.1) Evaluate current controls 1.2) Perform security risk assessment 1.3) Perform Zero Trust maturity assessment.

1.1) Evaluate Current Controls

An enterprise must identify its current security capabilities. It is essential to check and monitor whether the current security policies are compatible or adaptable with the zero trust principles [43]. In addition, migrating to ZTA may result in integration issues for the existing systems. Therefore, the migration team should have an appropriate plan to assess the existing legacy systems and determine whether these systems can function well in the ZT environment.

1.2) Perform Security Risk Assessment

An enterprise must determine internal and external threats and potential risks. This information can help an enterprise understand security patterns that can be utilized in the ZT environment [44]. Furthermore, an enterprise should perform a security risk assessment to determine assets or resources that must be protected [4].

1.3) Perform Zero Trust Maturity Assessment

An enterprise should conduct the Zero Trust maturity assessment. The enterprise also needs to define the ZT maturity state and specify the critical success factors [21], [45]. By doing this maturity assessment, the enterprise can better understand the current security

controls. Moreover, the goals and timeline for achieving the desired maturity state should be identified [20].

2) Perform Resource Discovery

To gain a complete view of all resources, an enterprise should define the protected surface, sensitive data, and business process flows [11], [22]. However, the enterprise should understand that it is not necessary to have a complete picture and full visibility of every data flow. Instead, the enterprise can utilize an observational strategy to acquire and analyze the data flows [13], [46]. In addition, an enterprise should examine assets, such as data, service accounts, devices, applications, services, hardware, and configuration management, to identify protecting surfaces before a Zero Trust deployment [4]. Moreover, sensitive data and business process flows should also be defined before deploying ZTA [11].

Data discovery and classification should be performed to determine all the data processing activities. For example, the enterprise may set up an inventory of data repositories to identify data protection levels. Furthermore, the network segmentation should be carried out according to data classification [22]. Additionally, the business process workflows should be mapped with a protecting surface to understand dependencies. This can help an enterprise to develop appropriate security policies. Moreover, the enterprise should appropriately determine who can access sensitive data based on the data and business process workflows [38].

5.2.3 Process III – Architect ZTA

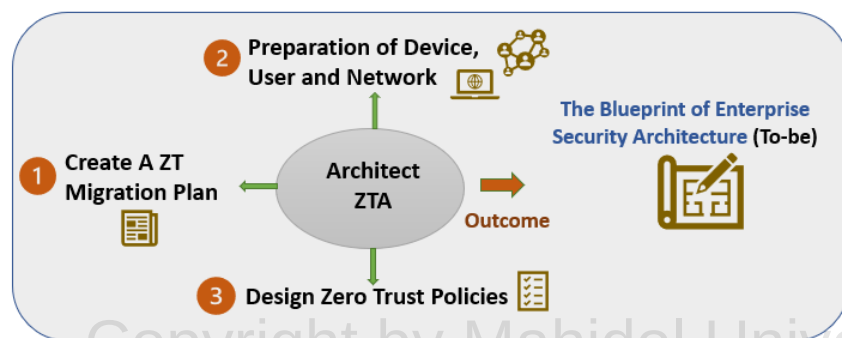


Figure 5.6: Process III – Architect ZTA

This process is to establish a Zero Trust migration plan that an enterprise uses to deploy ZTA. In addition, an enterprise must properly prepare devices, users, and networks for implementing ZTA. Moreover, the enterprise must appropriately develop the Zero Trust policies to provide efficient security controls. Thus, the outcome of this process is setting up a target enterprise security architecture which is a desired state of ZTA, as shown in figure 5.6.

1) Create a ZTA Migration Plan

The available zero-trust solutions and technologies should be carefully chosen before ZTA is implemented in an enterprise [35]. Hence, the enterprise should choose suitable and reliable vendors who offer zero-trust solutions that meet the needs and requirements. Furthermore, it is important to comprehensively understand the business objectives and technical requirements before buying zero-trust solutions. The enterprise should be aware of software interoperability to prevent vendor lock-in issues. Additionally, the enterprise should develop an implementation plan to divide and prioritize implantation tasks [3]. Test plans and performance assessment plans should also be developed to evaluate the success and effectiveness of the ZTA migration.

2) Preparation of Device, User, and Network

An enterprise must establish a Device Inventory Database to secure the devices [47]. This database is used to manage all devices in an enterprise's network, allowing only registered devices to access an enterprise's network [16], [30]. Therefore, all devices should have appropriate security controls and be continually observed to detect potential vulnerabilities [46].

To secure users, an enterprise should develop a User Database to manage all users as well as the group of users' membership [16]. When assigning and setting up users' roles, following the least privilege principles and acceptable user management is essential. The group of users includes business users, clients and partners of the enterprise, and IT users who can modify user access rights and other configurations. Moreover, an enterprise must ensure Multi-Factor Authentication (MFA) is implemented, and users' redundant access rights are revoked [20], [47]. Moreover, the enterprise should also adopt privileged identity management (PIM) and other necessary administrative controls [21].

To deploy an unprivileged network, all users and devices must be assigned to the appropriate network. The enterprise should manage sensitive data and allow user access based on planned segmentation [22]. In addition, the enterprise should put identified assets into logical groups in accordance with business process workflows. However, it is crucial to not over-segmenting or under-segmenting the network [48]. All traffic must pass through segmentation gateways before accessing to the protected resources. A user's access level should also be permitted based on a per-request basis [16]. Moreover, an enterprise must ensure that network asset visibility and security standards are implemented.

3) Design Zero Trust Policies

When developing security policies used in the ZT environment, the policies should be appropriately created, tested, and redefined based on resources and identified transaction flows [13], [36], [47], [48]. For example, an enterprise can utilize the Kipling Method, which defines the who, what, when, where, and why of user access to resources [38], [49]. This approach might serve as the foundation for one strategy for developing the ZT policies. In addition, the ZT policies should be checked that they are correct, consistent, minimal, and complete. For instance, the ZT policies should be validated to ensure they are not duplicated or redundant.

5.2.4 Process IV – Zero Trust Transformation



Figure 5.7: Process IV – Zero Trust Transformation

As illustrated in figure 5.7, this process begins when an enterprise chooses the candidate group for migration and launches the initial deployment. Then, the selected group of candidates is migrated to the unprivileged network simulation for a

certain period as the test group until the migration team can ensure the success of the migration. After that, the migration team starts rolling out the following groups of candidates. Finally, the measurement of ZTA implementation should be undertaken to ensure that the migration has proceeded as planned.

1) A Pilot Program to A Full Production Migration

1.1) Candidate Group Identification

The ZTA migration should be executed in small-scale and manageable projects [24]. Hence, an enterprise should identify prospective groups of candidates and create the candidate workflows with low-risk migration strategy [13], [16]. For instance, an enterprise may classify the users into three groups. The first group is the test group that are carefully selected to ensure that low-risk migration can be executed. External users and internal users are the next two categories. External users are users that have access to the enterprise's resources outside the corporate network. Internal users are users who gain access to company resources through the enterprise network [47].

Some users may not be ready to migrate to the ZT network. Therefore, the migration team should provide methods for these users to request temporary exemptions for the ZTA migration. The migration team may list these users in the workflows that were not yet qualified. When users are ready to migrate to ZTA, users should be informed or notified that they are eligible for the migration [50].

1.2) Migration Methods

Three main phases must be taken into consideration to minimize user disruptions during migrating to ZTA.

Phase 1: Production Pilot

An enterprise should prepare the pilot group of users or the test group for the initial migration to deploy in the Zero Trust platform or the unprivileged network [16], [24]. The registered devices must also be assigned to this unprivileged network. Moreover, all applications must run through the access proxy [45], [51]. Thus, the applications should be

ensured that they meet requirements of the access proxy or supported protocols. After most applications run through the access proxy, an enterprise should discourage users from using the VPN, and it should be provided to users who need to use it [16]. In this phase, the unprivileged simulation will simulate network behavior by monitoring all users' devices. Finally, an enterprise should deploy the Zero Trust platform with security controls or in audit mode to ensure that users can be switched or rolled back to the old systems [3].

Phase 2: Validate Pilot Results

At this phase, users operate in the unprivileged network simulation in audit mode for a well-defined period until the migration team can ensure the qualified traffic. After that, the qualified users and devices can be activated to assign to the unprivileged network [16], [23]. Next, the migration team should verify and validate the pilot program results to determine whether this migration is successful or experience any issues. If encountering some issues, the migration team should switch back to the old systems and test them again until it can be ensured that the pilot program can proceed as planned [23], [24].

Phase 3: Full Production Rollout

In this phase, the remaining groups of users must continue to deploy to the unprivileged network. During this stage, the migration team should prepare to transfer from the test environment to the production environment [13], [24]. In addition, the migration team can begin to decommission the old systems or technologies, and the full enforcement of the ZT platform can be activated [23].

2) Measure Implementation Success & Error Remediation

The success of the ZTA implementation and the effectiveness must be evaluated by using the test plan and implementation metrics. Furthermore, if there are any issues or errors, the migration team should provide solutions or channels to manage error remediation [30]. For instance, an enterprise may provide a self-remediate channel

for users to solve simple problems or errors by following remediation instructions or methods. In addition, a self-service help channel should also be established to answer frequently asked questions. The enterprise can also send an automatic email to inform users about the migration project's timeline and the impacts of this migration project [50], [51].

To support complex cases, the support team should manage and troubleshoot to help users. Hence, the support team should be trained and educated to assist users who need helps and get affected by interruptions. The team must help users to get back to the normal stage as soon as possible [46]. Once the migration team gains confidence with all the functions in the ZT environment, the success of the ZTA migration should be promoted to gain support and raise awareness among all stakeholders [38].

5.2.5 Process V – Monitoring and Maintenance

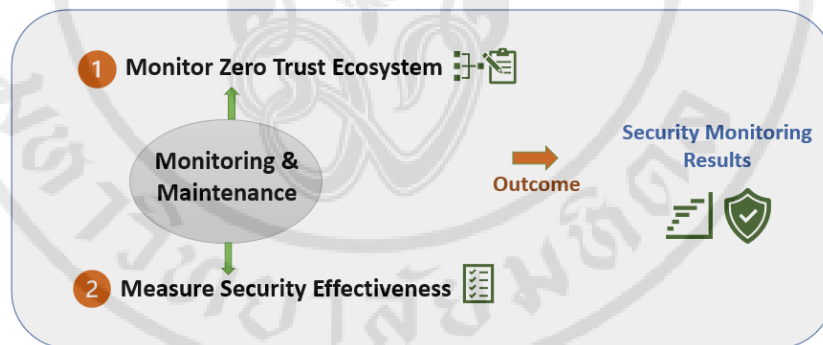


Figure 5.8: Process V – Monitoring and Maintenance

An enterprise must continue monitoring the ZTA ecosystem to ensure that all functions and components operate as intended. Furthermore, an enterprise should measure user experience and security effectiveness. This evaluation will help an enterprise acquire security monitoring results and ensure that the components in the ZT environment are working efficiently, as depicted in figure 5.8.

1) Monitor Zero Trust Ecosystem

In order to monitor and gain visibility of the user and network activity, an enterprise should analyze and log all network traffic in real-time [38], [46]. Furthermore, it is crucial to monitor the availability of services and network components for IT operation monitoring [49]. In addition, an enterprise should monitor all IT infrastructure

components. The enterprise must also check compliance monitoring, monitor security baseline, vulnerability scanning, and data breach detection. An enterprise can utilize security analytics tools to help monitor the ZTA [11]. However, it should be ensured that existing analytics tools can be executed and placed in the logical architecture [22].

2) Measure Security Effectiveness

After successfully migrating to ZTA, an enterprise should evaluate security effectiveness to ensure the ZTA is effective. Friction or interruptions of bad user experience should be measures to ensure that users can use the systems smoothly and securely [37]. User experience can be evaluated by checking security interruptions in user workflow. For instance, when users are prompted to multifactor authentication or drop in application usage because login fails. Moreover, an enterprise should evaluate security effectiveness so that the ZTA can provide better security controls. As a result, security incidents should be reduced in quantity and the impacts of the incidents. Security effectiveness can be evaluated by security incidents or the percentage of time IT users spend on low-value activities, such as password reset [37].

5.2.6 Process VI – Optimize ZTA Security

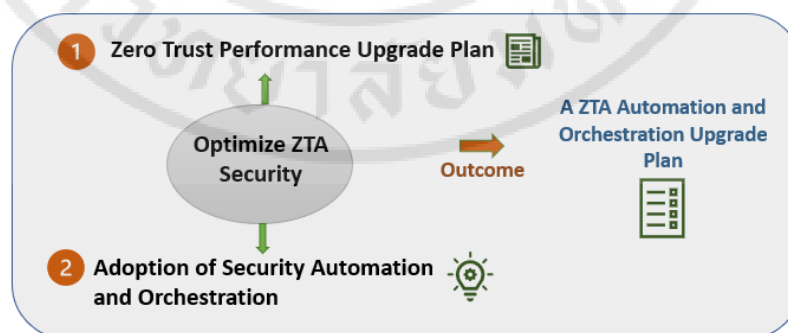


Figure 5.9: Process VI – Optimize ZTA Security

After migrating to ZTA, an enterprise should have the plan to optimize the security effectiveness of ZTA. Therefore, an enterprise should assess the efficacy of current zero-trust solutions and create a plan to upgrade its capabilities. In addition, the zero trust solutions should provide accurate responses in automated actions as much as possible. Thus, security automation and orchestration tools should be integrated to enhance the zero trust capabilities in more automated methods, as shown in figure 5.9.

1) Zero Trust Performance Upgrade Plan

The next stage after successfully implementing ZTA in an enterprise is to consider upgrading the capability and maturity of the ZTA. In order to upgrade its capability and maturity, an enterprise should assess the security performances and create plans to enhance the zero-trust performance [38], [45].

2) Adoption of Security Automation and Orchestration

To improve the performance of zero trust capabilities, the enterprise should evaluate manual security operations or procedures and have plans to translate those procedures into technology automation [11], [22]. Moreover, security automation and orchestration should be employed to automatically detect security risks as quickly as possible. SOAR (security orchestration, automation, and response) or security information and event management (SIEM) tools can be employed to integrate into the ZTA [36], [46]. These tools can improve zero-trust capabilities with a high level of automation and orchestration.

CHAPTER VI

FRAMEWORK EVALUATION AND RESULTS

This chapter describes framework evaluation for assessing the ZTA migration frameworks. Firstly, we explain the generic and ZTA-specific criteria that we use to evaluate ZTA migration frameworks. Secondly, we discuss the evaluation results of generic criteria. Thirdly, the evaluation results of ZTA-specific criteria are also provided. Finally, the detailed evaluation results in each criterion are described.

6.1 Framework Evaluation

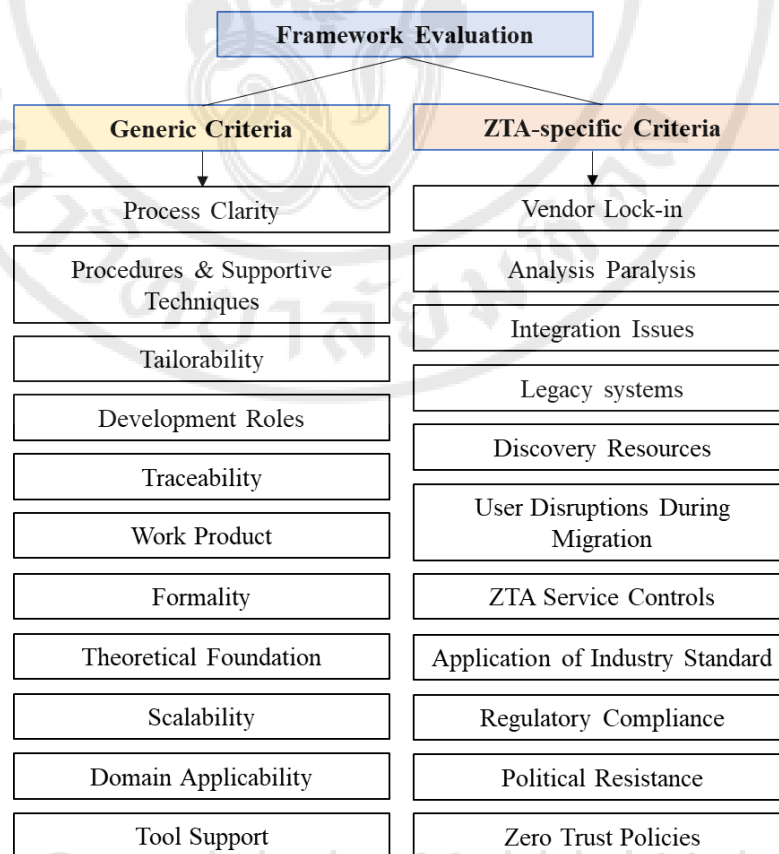


Figure 6.1: Framework Evaluation Criteria

As shown in figure 6.1, we develop an evaluation framework that specify criteria to evaluate a proposed ZTA migration framework and others ZTA migration frameworks that we obtained for the analysis. This evaluation framework will help ensure the quality, usability, and effectiveness of the ZTA migration framework. Each framework from other studies as well as our proposed comprehensive framework for migrating to ZTA are evaluated using the evaluation framework that specific question for each criterion are assesses.

The evaluation framework helps us to characterize and provide answers to our research objectives. This evaluation framework is composed of generic and ZTA-specific criteria that use to assess the ZTA migration framework. Hence, it provides suitable and sufficient method to evaluate the ZTA migration framework. In addition, the criteria are comprehensive enough to help us analyze the differences and similarity among the ZTA migration frameworks. Furthermore, the type of criteria for evaluation includes scale, Boolean, and descriptive criteria, as depicted in Table 6.1 and 6.3 The evaluation results of each framework are assessed based in the degree of evidence of methods and techniques, we found in their migration practices.

6.1.1 Generic Criteria for Evaluation

For generic criteria in framework evaluation, we applied the study of M. Fahmideh et al. [31] to evaluate the ZTA migration frameworks. This study created the evaluation framework to assess the cloud migration process by critically defining generic and cloud-specific evaluation criteria. The generic criteria were clearly defined as the study comprehensively analyzed and synthesized from existing frameworks in software engineering. The description of each criterion is as follows.

1) Process Clarity

This criterion clarifies and specifies actions or activities in the ZTA migration process. The ZTA migration team can use the detailed guidance description to understand the actions required for migrating to ZTA.

2) Procedure & supportive techniques

This criterion emphasizes the specific procedures and supportive techniques for ZTA implementation. It includes the tasks or activities in each process

that the migration team will perform when deploying ZTA. Supportive techniques in the ZTA migration include IT security risk assessment, ZTA maturity assessment, and resource discovery.

3) Tailorability

It is important to ensure that the framework is flexible enough to support various ZTA migration project scenarios. Moreover, the assumptions to apply the framework should not be based on a one-fits-all approach. For example, mechanisms, techniques, or tools can be provided for customizing ZTA requirements.

4) Development roles

This criterion aims to determine whether the framework identifies the roles, responsibilities, or necessary skills of the ZTA implementers. For example, understanding development roles in ZTA migration can help an enterprise to understand the required expertise to implement ZTA. The development roles may include business executives, IT executives, enterprise architects, and information security.

5) Traceability

Traceability refers to the connection or relationship of the whole process model where each process should be connected and traceable. Therefore, it is essential to provide traceability between processes or activities throughout the lifecycle of ZTA migration. As a result, this criterion will help ZTA implementers understand the relationship between the previous and the following migration processes.

6) Work product

This criterion refers to appropriate work products that should be created for each migration process or the whole migration lifecycle. Work products are essential for a recommended framework as they can help an enterprise understand deliverables for the ZTA migration process.

7) Formality

The formality criterion is to evaluate the framework or work products that provide precise and unambiguous mechanisms for ZTA migration. In addition, it considers the connections between work products.

8) Theoretical foundation

This criterion is to evaluate whether the ZTA migration framework theoretical knowledge or methodology in their migration practices. For example, the theoretical knowledge or methodology may include information technology and software engineering.

9) Scalability

The scalability criterion aims to understand the framework's applicability and whether it can support various sizes of ZTA migration projects. For example, some migration frameworks may be appropriate to handle the large-scale and complex workload for migration. On the other hand, other frameworks may be suitable for managing not complex migration project sizes. The factors to consider scalability include the degree of interconnectivity of activities, workloads, supported tools, human resources, and applications.

10) Domain Applicability

Domain applicability seeks to understand the domain, area, or industry to which the framework can be applied. For instance, the domain applicability of the ZTA migration framework may be applied to various industries, such as banking and insurance, supply chain and logistics, and healthcare organizations.

11) Tool support

Tool support refers to the tools used to support the ZTA migration framework proposed or recommended by the framework. The tool support can be either the tools developed by the framework or existing third-party tools in the market of the ZT solutions. For example, the ZT platform, the unprivileged network simulation, SOAR, and SIEM.

As shown in table 6.1, each evaluation criterion is used to assess the ZTA migration frameworks, including our proposed comprehensive ZTA migration framework. The results from the evaluation can help us understand characteristics, usability and the differences among the ZTA migration frameworks.

Table 6.1: Framework Evaluation – Generic Criteria

No.	Evaluation criterion	Evaluation question	Criterion Type	Description
1.	Process Clarity	Does the framework provide a clear description of the suggested processes and activities?	Scale	■ The framework explicitly provides a clear description of the activities for conducting ZTA migration process. ▣ The framework provides a general description for some processes, but details are lacking. □ The framework provides either very partial description or no description for the processes or activities.
2.	Procedures & Supportive Techniques	Does the framework provide procedures or supportive techniques to perform each process?	Scale	■ The framework offers techniques or examples for each ZTA migration process. ▣ The framework offers techniques or examples for some activities in the ZTA migration process. □ The framework does not provide supportive techniques or examples for the ZTA migration process.
3.	Traceability	Does the framework identify the sequence of modelling or dependencies between processes?	Scale	■ The framework specifies traceability or dependencies in the migration process. ▣ The framework specific traceability for a subset of activities in the migration process. □ Traceability or dependencies links between processes have not been specified.
4.	Tailorability	Is the framework based on a one-fits-all assumption or define adaptative mechanisms for migration? Is the framework be expressed in the form of method fragments or process components?	Scale	■ The framework explicitly defines mechanisms to configure and modify its suggested process. ▣ The framework provides a basis of method fragments or process components so that the tailoring process can be facilitated. □ There is no method fragments or process components that supports tailoring by the framework.

No.	Evaluation criterion	Evaluation question	Criterion Type	Description
5.	Tool Support	Does the framework suggest or provide guidelines of the tools that support the ZTA migration process?	Scale	■ The framework clearly suggests or provides tools for the whole ZTA migration process. ▣ The framework suggests or provides tools for some activities in the ZTA migration process. □ The framework neither provides tools nor refers to tools for the ZTA migration.
6.	Scalability	Is the framework applicable to handle various migration sizes?	Boolean	Yes: The framework explicitly defines mechanisms to support various migration sizes and its scalability has been demonstrated in a real project. No: The framework does not support scalability.
7.	Formality	Does the framework provide a degree of formality on technical aspects?	Boolean	Yes: The framework provides formal techniques for some activities. No: There is no formalism supported by the framework.
8.	Theoretical foundation	Is the framework inspired or developed based on the existing software engineering paradigms or practice?	Descriptive	
9.	Work-Products	What work-products are described by the framework to produce in the ZTA migration process?	Descriptive	
10.	Development Roles	What development roles, who are responsible for performing migration activities or any stakeholder who are involved, are defined by the framework?	Descriptive	
11.	Domain Applicability	What are application domains for which the framework offer?	Descriptive	

6.1.2 ZTA-specific Criteria for Evaluation

For ZTA-specific criteria, we used the ZTA migration challenges identified from our analysis to evaluate other ZTA migration frameworks and our proposed comprehensive ZTA migration framework, as illustrated in table 6.2. The considerations of these challenges can help us understand whether the ZTA migration frameworks can address or take the migration challenges into account for their migration methods.

Table 6.2: A List of ZT Migration Challenges

ZT Migration Challenges	
1	Vendor Lock-in
2	Analysis Paralysis
3	Integration Issues
4	Legacy Systems
5	Discovery Resources
6	User Disruptions During Migration
7	ZTA Services Controls
8	Application of Industry Standard
9	Regulatory Compliance
10	Political Resistance
11	Zero Trust Policies

Table 6.3: Framework Evaluation – ZTA-specific Criteria

No.	Evaluation criterion	Evaluation question	Criterion Type	Description
1.	Vendor Lock-in	Does the framework provide a clear description or mechanisms to manage Zero Trust vendor lock-in issues?	Scale	■ The framework offers clear techniques or examples for to manage Zero Trust vendor lock-in issues in the migration process. ▣ The framework offers techniques or examples for some activities to manage Zero Trust vendor lock-in issues. □ The framework does not provide supportive techniques or example for activities to manage Zero Trust vendor lock-in issues.

No.	Evaluation criterion	Evaluation question	Criterion Type	Description
2.	Analysis Paralysis	What are the strategies or techniques to analyze or perform activities of the migration process?	Scale	■ The framework explicitly offers strategies or techniques to analyze or perform activities of the migration process. ■ The framework offers general strategies or techniques to analyze or perform some activities of the migration process. □ The framework does not provide supportive strategies or techniques to analyze or perform activities of the migration process.
3.	Integration Issues	Does the framework provide a clear description or mechanisms to manage integration issues?	Scale	■ The framework explicitly offers clear techniques or examples for to manage integration issues in the migration process. ■ The framework offers techniques or example for some activities to manage integration issues. □ The framework does not provide supportive techniques or example for activities to manage integration issues.
4.	Legacy systems	Does the framework provide a clear description or mechanisms to manage legacy systems issues?	Scale	■ The framework explicitly offers clear techniques or examples for to manage legacy systems issues in the migration process. ■ The framework offers techniques or example for some activities to manage legacy systems issues. □ The framework does not provide supportive techniques or example for activities to manage legacy systems issues.
5.	Discovery Resources	Does the framework define techniques or mechanisms to discover resources?	Scale	■ The framework explicitly defines techniques or mechanisms to discover resources. ■ The framework provides a basis of method fragments so that discovery resources can be facilitated. □ There is no discover resources techniques or mechanisms supported by the framework.

No.	Evaluation criterion	Evaluation question	Criterion Type	Description
6.	User Disruptions During Migration	Does the framework provide a clear description or mechanisms to manage user disruptions during migration?	Scale	■ The framework explicitly offers clear techniques or examples for to manage user disruptions in the migration process. ▣ The framework offers techniques or example for some activities to manage user disruptions in the migration process. □ The framework does not provide supportive techniques or example for activities to manage user disruptions in the migration process.
7.	ZTA Service Controls	Does the framework provide clear techniques or tools to support ZTA service controls or a ZT platform?	Scale	■ The framework explicitly provides clear techniques or tools to support ZTA service controls or a ZT platform. ▣ The framework provides techniques or tools for some activities to support ZTA service controls or a ZT platform. □ The framework neither provides techniques or tools to support ZTA service controls or a ZT platform.
8.	Application of Industry Standard	Does the framework apply industry standard regarding Zero Trust migration or implementation in their migration process?	Scale	■ The framework explicitly specifies applying industry standards for conducting the migration process. ▣ The framework specifies applying industry standards for conducting the migration process for some activities. □ The framework does not specify applying industry standards for conducting the migration process.
9.	Regulatory Compliance	Does the framework take regulatory compliance into consideration in the migration process?	Scale	■ The framework explicitly specifies consideration of regulatory compliance for conducting the migration process. ▣ The framework specifies consideration of regulatory compliance for conducting the migration process for some activities. □ The framework does not specify consideration of regulatory

No.	Evaluation criterion	Evaluation question	Criterion Type	Description
				compliance for conducting the migration process.
10.	Political Resistance	Does the framework provide methods or techniques to manage political resistance in the migration?	Scale	■ The framework explicitly specifies methods or techniques to manage political resistance in the migration. ▣ The framework specifies methods or techniques to manage political resistance for some activities in the migration. □ The framework does not specify methods or techniques to manage political resistance in the migration.
11.	Zero Trust Policies	Does the framework provide methods or techniques to establish and manage Zero Trust Policy?	Scale	■ The framework explicitly provides methods or techniques to establish and manage Zero Trust Policy. ▣ The framework provides methods or techniques to establish and manage Zero Trust Policy but details are lacking. □ The framework does not provide methods or techniques to establish and manage Zero Trust Policy.

6.2 Evaluation Results

6.2.1 The Results of Generic Criteria for Evaluation

We evaluate 21 ZTA migration frameworks we obtained for our analysis to understand each framework's characteristics and effectiveness. The purpose of assessing generic criteria is to know how the ZTA migration framework can address and fulfill criteria important for software engineering and information technology practices. The evaluation results of generic criteria are illustrated in table 6.4.

Table 6.4: Evaluation Result – General Criteria

■ = Fully supported, ▣ = Partially supported, □ = Not supported, Yes = Criterion is met, No = Criterion is not met							
Framework	Process clarity	Procedures & Supportive Techniques	Traceability	Tailorability	Tool Support	Scalability	Formality
[A1]	□	□	□	□	□	No	No
[A2]	▣	▣	▣	▣	■	No	No
[A3]	▣	▣	□	▣	▣	Yes	Yes
[A4]	▣	■	□	■	■	No	Yes
[A5]	□	▣	□	□	■	Yes	No
[A6]	■	▣	▣	▣	□	No	Yes
[A7]	□	□	□	▣	■	Yes	Yes
[A8]	■	■	▣	▣	▣	Yes	Yes
[A9]	■	▣	▣	■	□	Yes	No
[A10]	▣	□	▣	■	□	Yes	Yes
[A11]	■	■	▣	▣	■	Yes	Yes
[A12]	■	▣	▣	■	■	Yes	Yes
[A13]	▣	□	□	▣	■	Yes	Yes
[A14]	■	■	▣	▣	■	Yes	Yes
[A15]	■	■	▣	■	■	Yes	Yes
[A16]	▣	▣	▣	■	■	Yes	Yes
[A17]	▣	▣	▣	▣	▣	Yes	Yes
[A18]	■	■	▣	▣	■	Yes	Yes
[A19]	▣	▣	□	▣	□	Yes	Yes
[A20]	□	□	□	▣	▣	Yes	No
[A21]	▣	□	□	▣	▣	Yes	Yes
Fully supported	38%	29%	0	29%	52%	-	-
Partially supported	43%	43%	57%	61%	24%	-	-
Not supported	19%	28%	43%	10%	24%	-	-
A Proposed Framework	■	■	■	■	▣	Yes	Yes

The evaluation results of 11 generic criteria are explained as follows.

1) Process Clarity

Among 21 ZTA migration frameworks obtained for our analysis, we found 8 studies (38%) that clearly specify their activities in the ZTA migration practices as the detailed guidance is provided. However, most frameworks (43%) give a general description, and 10 studies (19%) partially explain their migration practices.

2) Procedure & supportive techniques

Most frameworks (43%) offer techniques or examples for some activities in the ZTA migration process. There are 6 ZTA migration frameworks (29%) that explicitly offer techniques or examples for each ZTA migration process. On the other hand, there are 6 frameworks (28%) which do not provide supportive techniques or examples for the ZTA migration process.

3) Tailorability

Most frameworks (61%) provide a basis for method fragments or process components of the tailoring process. The assumptions of 13 frameworks (29%) show that they are based on a one-fits-all approach. There are 6 frameworks demonstrating that their framework can support various ZTA migration project scenarios. However, 2 frameworks (10%) do not describe method fragments or process components that support tailoring.

4) Development roles

The descriptive evaluation results of development roles in ZTA migration are illustrated in table 6.5.

Table 6.5: Evaluation Result – Development Roles

Framework Code	Development Roles
[A2], [A3], [A5], [A6], [A9], [A17], [A20]	Not specified
[A1]	This framework specifies only user role when accessing to sensitive data.
[A4]	This framework specifies only user role.
[A7]	CISO and Security Professionals
[A8]	- Government board - Architecture review board - Change management board

Framework Code	Development Roles
	- Security team
[A10]	- Cybersecurity managers - Network administrators - Managers - Administrators
[A11]	- Top level management - IT team - Migration Team - HR team
[A12]	- Business Leadership such as CEO CIO
[A14]	A cross-functional team of business and technical decision makers, IT, information security, infrastructure, application developers, and other stakeholders.
[A15]	- Business users - IT users - Partners and Clients
[A16]	- Business and IT stakeholders (The board members, IT executives, enterprise architects, application owners, IT operation team)
[A18]	- Administrators
[A19]	- The ZT migration team - The read team
[A20]	- The ZT migration team

5) Traceability

It is significant that no ZTA migration frameworks fully specify traceability or dependencies in the migration process. However, we found 12 frameworks (57%) provide traceability for a subset of activities in the migration process. Moreover, 8 ZTA migration frameworks (43%) do not specify traceability or dependencies links between processes.

6) Work product

The descriptive evaluation results of work products for each framework are shown in table 6.6.

Table 6.6: Evaluation Result – Work Product

Framework Code	Work Product
[A1], [A5], [A6], [A9], [A10], [A12], [A14], [A15], [A16], [A17], [A19], [A20], [A21]	Not specified

Framework Code	Work Product
[A2]	A checklist of security controls to integrate a ZTA
[A4]	A zero-trust network topology (micro segmentation)
[A7]	Prototype Minimal Viable Product (MVP) of portal Zero Trust framework
[A8]	Proof of Concept results and Zero trust platform production pilot
[A11]	Unprivileged network simulation
[A13]	Adaptive Security Platform
[A18]	Enterprise Application Access

7) Formality

The descriptive evaluation results of formality of each framework are shown in table 6.7.

Table 6.7: Evaluation Result – Formality

Framework Code	Formality
[A3], [A4], [A6], [A7], [A8], [A10], [A11], [A12], [A13], [A14], [A15], [A16], [A17], [A18], [A19], [A21]	- The framework provides formal techniques in which precise and unambiguous mechanisms for ZTA migration are described for some processes or activities.
[A1], [A2], [A4], [A5], [A9], [A20]	- The framework does not provide formal techniques in which precise and unambiguous mechanisms for ZTA migration are described for some processes or activities.

8) Theoretical foundation

The descriptive evaluation results of theoretical foundation using in each framework are illustrated in table 6.8.

Table 6.8: Evaluation Result – Theoretical Foundation

Framework Code	Theoretical Foundation
[A4], [A5], [A9], [A11], [A12], [A13], [A15], [A17], [A18], [A19], [A21]	Not specified
[A1]	This framework considers access control models, namely attribute based access control (ABAC) and role-based access control (RBAC)

Framework Code	Theoretical Foundation
[A2]	This framework uses Software Bill of Materials (SBOM) to build their solution.
[A3]	This framework is designed based on MITRE ATT&CK framework.
[A6]	This framework is design based on network security theory, especially network micro segmentation design.
[A7]	This framework is design based on Hevner's Design Science Research Framework.
[A8]	This framework is designed based on project management methodology.
[A10]	This framework is designed based on risk management.
[A14]	Zero Trust Policies are designed based on Kipling Method.
[A16]	This framework is designed based on project management methodology.
[A20]	Zero Trust Policies are designed based on Kipling Method.

9) Scalability

The descriptive evaluation results of scalability that each framework provided are illustrated in table 6.9.

Table 6.9: Evaluation Result – Scalability

Framework Code	Scalability
[A3], [A5], [A7], [A8], [A9], [A10], [A11], [A12], [A13], [A14], [A15], [A16], [A17], [A18], [A19], [A20], [A21]	- The framework explicitly specifies methods to accommodate various ZTA migration sizes and its scalability has been shown in the ZTA migration projects. - The framework demonstrates interconnectivity of activities, workloads, supported tools, human resources, or applications to support the ZTA migration processes and activities.
[A1], [A2], [A4], [A6]	The framework does not support scalability.

10) Domain Applicability

The descriptive evaluation results of domain applicability of each framework are illustrated in table 6.10.

Table 6.10: Evaluation Result – Domain Applicability

Framework Code	Domain Applicability
[A5], [A10], [A11], [A12], [A13], [A14], [A15], [A16], [A17], [A20], [A21]	The framework is generally designed to support enterprises planning to migrate to ZTA.
[A3], [A9]	Not specified
[A1]	An enterprise that has various users located in different part of the world.
[A2]	Supply Chain and Logistics
[A4]	A small-to medium-sized healthcare organization
[A6]	An enterprise that has heterogeneous environment, namely private cloud, public cloud and on-premise facilities.
[A7]	Banking and Insurance
[A8]	Transportation Services
[A19]	The federal government of the United States

11) Tool support

We found 11 ZTA migration frameworks (52%) clearly suggest or provide tools for the whole ZTA migration process. There are 5 studies (24%) that suggest or offer tools for some activities in the ZTA migration process. Furthermore, we found 5 ZTA migration frameworks (24%) neither provide tools nor refer to tools for the ZTA migration.

6.2.2 The Results of ZTA-specific Criteria for Evaluation

The evaluation obtained 21 ZTA migration frameworks by using ZTA-specific criteria for assessment. This evaluation will help us understand whether the studies can address or consider ZTA migration challenges in migration practices. The evaluation results are shown in table 6.5.

Table 6.11: Evaluation Result – ZTA-specific Criteria

[illegible]

1) Vendor Lock-in

It is significant that only 2 ZTA migration frameworks (10%) provide clear techniques or examples to manage Zero Trust vendor lock-in issues in the migration process. On the other hand, most frameworks (85%) do not provide supportive techniques or examples for activities to manage Zero Trust vendor lock-in issues. Moreover, we found 1 ZTA migration framework (5%) does not provide supportive techniques or examples for activities to address Zero Trust vendor lock-in issues.

2) Analysis Paralysis

We found 12 ZTA migration frameworks (57%) explicitly offer strategies or techniques to analyze or perform activities of the migration process. In addition, 2 studies (10%) provide general strategies or techniques to analyze or perform some activities of the migration process. However, 7 ZTA migration frameworks (33%) do not provide supportive strategies or techniques to perform actions in their migration process.

3) Integration Issues

There are 8 ZTA migration frameworks (38%) explicitly offer clear techniques or examples to manage integration issues in the migration process. On the other hand, we found 8 ZTA migration frameworks (38%) do not provide supportive techniques or examples for activities to manage integration issues. In addition, 5 studies (24%) offer techniques or examples for some activities to handle this issue.

4) Legacy Systems

It is evident that 15 studies (71%) do not provide supportive techniques or example for activities to manage legacy systems issues. Moreover, we found 2 ZTA migration frameworks (10%) offers techniques or example for some activities to handle this issue. However, 4 studies (19%) explicitly offer clear techniques or examples to manage legacy systems issues in their migration process.

5) Discovery Resources

It is significant that most frameworks (62%) explicitly define techniques or mechanisms to discover resources in their practices. Moreover, there are 2 frameworks (10%) that provide some method fragments to discover resources.

However, we found 6 studies (28%) do not describe discover resources techniques or mechanisms in their migration methods.

6) User Disruptions During Migration

It is evident that most frameworks, 15 studies (71%), do not provide supportive techniques or examples for activities to manage user disruptions in the migration process. There is only 1 framework that offers methods for some activities to handle this issue. However, we found 5 studies (24%) offer techniques for some activities to manage this issue.

7) ZTA Service Controls

We found most frameworks, 13 studies (62%), explicitly provide clear techniques or tools to support ZTA service controls or a ZT platform. However, there are 6 frameworks (28%) do not provide techniques or tools to support ZTA service controls. In addition, 2 studies (10%) partially provide techniques or tools for some activities to support ZTA service controls.

8) Application of Industry Standard

It is significant that most frameworks, 13 studies (62%), do not specify applying industry standards for conducting the migration process. On the other hand, we found 8 ZTA migration frameworks (38%) identify using industry standards for performing the migration process for some activities.

9) Regulatory Compliance

It is found that 10 ZTA migration frameworks (47.5%) explicitly specify consideration of regulatory compliance for conducting the migration process. On the contrary, 10 studies (47.5%) do not specify consideration of regulatory compliance in the ZTA migration. In addition, we found 1 study that partially defines the review of regulatory compliance only for some activities.

10) Political Resistance

Most frameworks, which are 13 studies (62%), do not have techniques to manage political resistance to migration. However, we found 5 ZTA migration frameworks (24%) fully support managing political resistance in the migration. In addition, 3 studies (14%) partially mention techniques to manage political resistance in migration.

11) Zero Trust Policies

It is obvious that many frameworks, which are 16 studies (76%), explicitly provide methods or techniques to establish and manage Zero Trust policies. Moreover, only 1 framework partially mentions managing Zero Trust policies in its practices. However, we found 4 studies (19%) do not provide methods or techniques to establish Zero Trust policies.



CHAPTER VII

DISCUSSION AND CONCLUSION

This chapter discusses this research by outlining interesting points in section 7.1. Firstly, the PRISMA Systematic review results are discussed. In addition, the gaps in other ZTA migration frameworks are also considered. Next, we discuss the evaluation results of other ZTA migration frameworks and the results of the proposed comprehensive ZTA migration framework. The limitations of this study are also explained in section 7.2. Finally, we conclude our research and provide direction for future works.

7.1 Discussion

This section discusses the PRISMA systematic review and the gaps in other ZTA migration frameworks. Moreover, we describe the evaluation results of other ZTA migration frameworks and the results of the proposed comprehensive ZTA migration framework.

7.1.1 The PRISMA Systematic Review Results

In this study, we conduct our systematic review using the PRISMA method. The PRISMA method provides efficient approaches for selecting and identifying qualified literature that we use for analysis in our study. In addition, the PRISMA methods help us acquire literature that is most relevant to our research as we specify criteria to include or exclude literature. For example, we perform the title and abstract of research articles and exclude literature that does not contribute to our research questions. As a result, the PRISMA helps us scope down to identify the literature that significantly contributes to our research question systematically.

To identify relevant literature, we conduct our search via academic and grey literature databases, such as websites. Regarding identifying studies via academic databases, we perform our literature search via reputable academic databases,

including IEEE Explore, ScienceDirect, ACM Digital Library, Web of Science, JSTOR, and SpringerLink. As a result, we found 9 studies that significantly contribute to our research questions and analysis. As for the grey literature search, we apply the guidelines by V. Garousi et al, [26].

The guidelines help us to acquire high-quality grey literature, such as white papers and reports, for our analysis. When performing a grey literature search, we found numerous studies from many sources that are relevant to ZTA migration, such as blogs, web articles, and reports. Hence, we utilize the guideline to select the most relevant and high-quality grey literature that significantly contributes to the analysis. Thus, we obtain 19 grey studies for our study.

The results from our PRISMA literature search imply there are currently very few academic studies and scholars intensively investigating and researching ZTA migration, as we found only 9 academic studies exploring ZTA migration. Hence, migrating to ZTA is an interesting area that scholars can study extensively. On the other hand, it is found that there are many grey literature publishing studies regarding ZTA migration. Thus, it is evident that the concepts of ZTA and its migration practices are gaining popularity in the industry.

7.1.2 The Gaps of Other ZTA Migration Frameworks

Framework Code	Strategize Zero Trust	Context Assessment	Architect ZTA	Zero Trust Transformations	Monitor and Maintenance	Optimize ZTA Security
[A1]		✓			✓	
[A2]		✓	✓			
[A3]		✓				
[A4]				✓		
[A5]		✓				
[A6]			✓			
[A7]	✓					
[A8]	✓	✓		✓		
[A9]		✓	✓		✓	✓
[A10]	✓	✓	✓	✓		
[A11]	✓		✓	✓		
[A12]	✓	✓	✓		✓	
[A13]	✓		✓			✓
[A14]	✓	✓	✓	✓	✓	✓
[A15]		✓	✓		✓	✓
[A16]	✓	✓	✓			
[A17]			✓			
[A18]		✓		✓		✓
[A19]	✓		✓	✓		
[A20]	✓		✓			
[A21]			✓		✓	
Total	10	12	14	7	6	5

Figure 7.1: The Gaps of Other ZTA Migration Frameworks

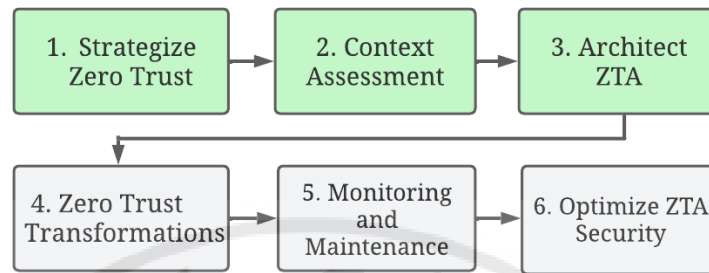


Figure 7.2: The Six Processes of ZTA Migration

As shown in table 7.1, it is found that several studies concentrate their ZTA migration on Process I - Strategize ZTA, Process II - Context Assessment, and Process III - Architect ZTA in their proposed migration practices. These three main processes are crucial for ZTA migration's success, as illustrated in figure 7.1. First, an enterprise must establish strategies and visions to migrate to ZTA. In addition, the enterprise must know the security architecture's current state and gain resource visibility before implementing ZTA. After that, it is essential to thoughtfully design and architect ZTA. As a result, an enterprise can have suitable ZTA implementation plans for deploying the target ZTA. The next stage is to use a low-risk migration approach to begin migrating the candidate migration groups.

It can be observed that Process IV - Zero Trust Transformations, Process V - Monitoring and Maintenance, and Process VI - Optimize ZTA security are not the main focus of many studies. As depicted in table 7.1, few studies emphasize the three core processes in their migration practices. However, it is essential to consider comprehensive migration processes to ensure a smooth transition and successfully migrate to ZTA.

7.1.3 The Evaluation Results of Other ZTA Migration Frameworks

Regarding the results of generic criteria for framework evaluation, it is found that most ZTA migration frameworks explicitly lack specifying traceability or dependencies in their migration practices. However, it is noticeable that only some activities with some traceability or dependencies are partially identified. Furthermore, many frameworks illustrate customization in some processes of their migration practices.

For example, the studies [S5] and [S10] include a risk assessment process to evaluate the current state assessment. Furthermore, the study [S20] and [S28] recommend establishing ZT policies based on the Kipling method. However, it is observed that many frameworks provide the tool support for migration. For example, [S2] uses the Software Bill of Materials (SBOM) to build their ZT solution. [S4] provides ZT network topology tool support. Moreover, [S11], [S19], and [S25] develop ZT security platforms as tools to facilitate ZTA migration.

As for the domain applicability criterion, most ZTA migration frameworks are generally developed to help enterprise planning migrate to ZTA. However, some frameworks are specifically designed to support particular domains. For example, [S2] establishes a ZTA migration framework to assist the supply chain and logistics. [S4] aims to support a small-to-medium-sized healthcare organization. Moreover, [S7] plans to support banking and insurance services. Finally, [S8] helps support transportation services.

For the work-product criterion, few obtained studies produce work products relating to their ZTA migration frameworks. Many frameworks lack demonstrating ZTA-related work products in their migration approaches. However, some studies provide work products for their ZTA migration. For example, [S2] presents a checklist of security controls to integrate a ZTA. Moreover, [S7] produces a prototype Minimal Viable Product (MVP) of the portal Zero Trust framework.

Regarding ZTA-specific criteria for framework evaluation, it is found that most frameworks lack consideration of vendor lock-in issues. However, based on our systematic literature search, many studies we obtained for the analysis are from the published reports by the ZT service providers. Hence, it is understandable that they are less likely to address this issue in their migration methods. In addition, we found that most frameworks lack consideration of the challenge of user disruption during migration. However, this issue is crucial that an enterprise should pay attention. The enterprise should establish a remediation service to support users when a service interruption may impact user productivity.

Additionally, political resistance is one of the challenges that many ZTA migration frameworks disregard. This issue is essential in the managerial aspect. Hence, it is recommended to implement a change management plan to tackle this

issue. An enterprise should get consensus and ensure that the negative impacts are appropriately handled.

7.1.4 The Evaluation Results of The Proposed Framework

From the evaluation results, the proposed ZTA migration framework can provide complete and comprehensive migration details. Overall, the proposed framework is more consistent as it depicts the main processes and sub-processes of migrating to ZTA. In addition, it is optimized by incorporating DevOps methodology, which concerns the whole life cycle of migration in both technical and managerial aspects of ZTA migration.

■ = Fully supported, ■ = Partially supported, □ = Not supported, Yes = Criterion is met, No = Criterion is not met							
Framework	Process clarity	Procedures & Supportive Techniques	Traceability	Tailorability	Tool Support	Scalability	Formality
A Proposed Framework	■	■	■	■	■	Yes	Yes

Figure 7.3: Generic criteria – Evaluation results of the proposed framework

Regarding the generic criteria of framework evaluation (Figure 7.2), it is noticeable that the proposed framework can address all requirements, such as process clarity, traceability, and tailorability. For instance, as for traceability and process clarity criteria, the proposed framework can address these issues as it shows consistent main processes, subprocesses, and the output of each process. As for the tool support criterion, this framework presents the guideline for ZTA migration as supportive techniques. This guideline can be used as a tool that provides checklists for an enterprise planning to implement ZTA. Moreover, the proposed framework demonstrates a low-risk migration strategy to migrate to ZTA in which risk assessment and ZTA mutuality assessment are considered.

■ = Fully supported, ■ = Partially supported, □ = Not supported											
Framework	Vendor Lock-in	Analysis Paralysis	Integration Issues	Legacy systems	Discovery Resources	User Disruptions During Migration	ZTA Service Controls	Application of Industry Standard	Regulatory Compliance	Political Resistance	Zero Trust Policies
A Proposed Framework	■	■	■	■	■	■	■	■	■	■	■

Figure 7.4: ZTA-specific criteria – Evaluation results of the proposed framework

As for ZTA-specific criteria (Figure 7.3), the proposed framework can address the challenges of ZTA migration. For instance, the framework elaborates on vendor lock-in issues in process III – Architect ZTA. In addition, the proposed framework emphasizes solving the issues of analysis paralysis, discovering resources, and political resistance. These issues are explicitly described in process I – Strategize Zero Trust and process II – Context Assessment. Moreover, the proposed framework also outlines establishing appropriate Zero Trust policies. This issue is clearly addressed in process III – Architect ZTA.

Therefore, the proposed comprehensive ZTA migration framework is proved effective as it provides comprehensive migration processes. Furthermore, the results from the framework evaluation show that it considers both generic and ZTA-specific criteria for framework development.

7.1.5 ZTA Migration in the Cloud Environment

Many enterprises currently host their data, systems, or applications on cloud infrastructure and services. They can be stored in data centers in various countries. Even though enterprises have less control over the cloud, they tend to trust cloud providers based on standards or certifications held by cloud providers [10][52]. However, the expansion of cloud services poses challenges to security and privacy, for example, identity theft and data breaches. As a result, the enterprises aim to enable ZTA to help increase security and reduce data breach risks.

The enterprises' architectures are now more hybrid infrastructure that integrates cloud services with on-premises. It is essential to check how end-users access the enterprise's cloud services when deploying ZTA with the cloud environments [53]. For example, the enterprise must check whether or not existing access controls are applied to cloud services. Furthermore, the enterprise must check cloud-host identity systems to that they grant authentication decisions based on the level of trust.

The studies by NIST [13] and J. Garbis [24] suggest deploying ZTA to a multi-cloud environment by utilizing policy enforcement points (PEPs). PEPs should be placed at the access point of each cloud service. This approach allows the ZT system to act as a component to execute identity-centric and dynamic access controls before granting subjects access to resources residing in the cloud environment. There are two approaches to placing PEPs as access controls to provide the ZT policies in the cloud services. The first model is cloud access control via co-located PEP.

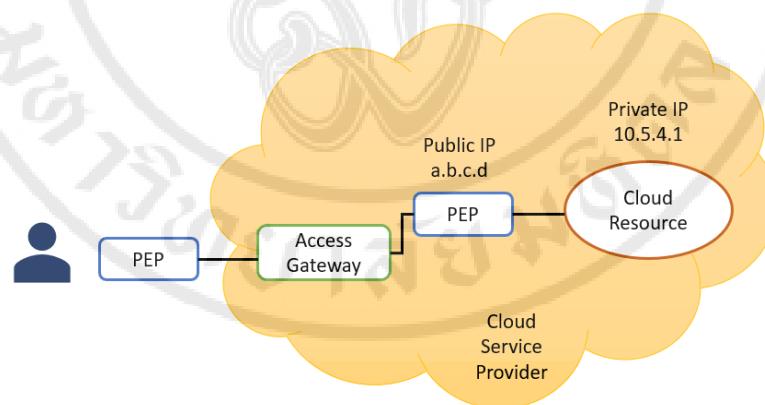


Figure 7.5: ZTA Cloud access control via co-located PEP [24]

In this scenario, a PEP implemented in the cloud environment is used as access controls to resources. An IP address is allocated and configured with the cloud service's access gateway. Thus, only traffics that originates the PEP is allowed to access cloud resources. The PEP can be accessed through the access gateway from any external IP address, including remote user devices. As a result, traffic is routed through the access gateway to the PEP, which then applies the ZT policies to the subjects [24].

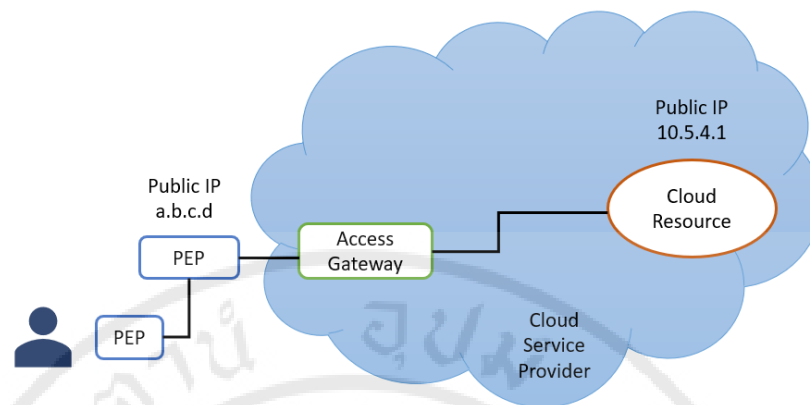


Figure 7.6: Cloud access control via remote PEP [24]

Another model is cloud access control via remote PEP. In this scenario, cloud services should have their public IP address to allow remote access. All traffic must come from the PEP's public IP address under a source IP restriction that will be enforced by the cloud service providers. This approach can enable dynamic access controls by the ZT platform to the cloud resources. However, this approach is suitable for encrypted protocols [24].

7.2 Limitations

This section describes the limitations of this study. The limitations of this study include publication bias and validating the proposed ZTA migration framework, as explained below.

7.2.1 Publication Bias

This study uses the PRISMA systematic review methods to select relevant published studies, including academic and grey literature related to the ZTA migration methods and practices. To select and identify relevant studies, we define appropriate keywords, such as “Zero Trust,” “Zero Trust Migration,” and “Zero Trust Implementation.” Moreover, we define inclusion and exclusion criteria to identify the most relevant studies that contribute to our research questions.

However, relevant studies might not be found by our defined keywords in the databases we use for the analysis. In addition, we only choose studies and research

that have been published in English, which might result in publication bias. The results from our literature search have found many studies published by ZT vendors. The ZT vendors propose their zero-trust solutions and ZTA migration from their perspectives. Although many studies provide comprehensive details of their migration practices, they are not fairly neutral as they also offer their ZT solutions for migration in their publications.

7.2.2 Framework Validation

At this stage, the proposed comprehensive ZTA migration framework has yet to undergo an experimental phase to validate its effectiveness of the proposed framework. Therefore, the validation of the proposed ZTA migration framework is evaluated based on the framework evaluation criteria we developed to assess our proposed framework. Besides, the evaluation criteria are also used to evaluate selected published studies from a systematic review. However, these criteria may not reflect all aspects of ZTA migration. For example, the effectiveness of functional components or the efficacy of ZTA after post-migration has yet to be discussed.

7.3 Conclusion

In this study, we develop a comprehensive framework for migrating to ZTA. This framework considers technical, managerial, and operational perspectives of migration. In addition, this framework also takes into account an effective and practical process-driven framework for migration. The proposed framework is constructed based on a systematic review by synthesizing and analyzing selected published studies relevant to ZTA migration methods and techniques. Furthermore, we optimize the proposed framework by incorporating the DevOps methodology. DevOps aims to create service quality from both the development and operational aspects of the service delivery lifecycle. Therefore, incorporating DevOps with the proposed framework help the ZTA migration framework to be more effective.

We present six main processes which combine subprocess and essential components for ZTA migration. The proposed ZTA migration processes are 1) Strategize Zero Trust, 2) context assessment, 3) Architect ZTA, 4) Zero Trust

transformation, 5) Monitoring and Maintenance, and 6) optimize ZTA security, respectively.

To validate the proposed ZTA migration framework, we use the framework evaluation criteria to assess the characteristics, similarities, and differences of each ZTA migration framework obtained for this study. In addition, the criteria also evaluate the effectiveness and usability of the proposed ZTA migration framework and other ZTA migration frameworks. The evaluation concerns crucial criteria related to software engineering and ZTA-related criteria. The evaluation results show that our proposed ZTA migration framework can comprehensively cover all the criteria of framework evaluation and provide complete and consistent processes for migrating to ZTA.

Therefore, the proposed comprehensive ZTA migration framework can be used as a reference model for effective transitioning to Zero Trust Architecture. We also present the guideline for implementing ZTA migration. This guideline provides practical checklists to implement ZTA in the enterprise. The enterprise planning to migrate to ZTA can utilize the comprehensive ZTA migration framework and the proposed guideline for their ZTA deployment.

7.4 Future Works

The proposed comprehensive ZTA migration framework can be optimized further by undergoing an experimental phase. This framework can be validated its usability and effectiveness by implementing the processes and relevant sub-processes in the controlled environment of an enterprise. The results from an experiment phase can be used to improve this ZTA migration framework to be more appropriate in the enterprise context. Moreover, as the proposed framework focuses on the overall processes of the ZTA migration, the detailed and comprehensive methods have yet to be thoroughly discussed. The technical techniques for deploying ZTA can be studied and investigated further to explore zero-trust technologies and prove how to implement them in the ZT environment.

REFERENCES

- 1 ACT-IAC. "Zero Trust Cybersecurity Current Trends." American Council for Technology-Industry Advisory Council (ACT-IAC), USA, 2019. Accessed: Nov. 25, 2022. [Online]. Available: <https://www.actiac.org/documents/zero-trust-cybersecurity-current-trends>
- 2 M. Bowen. "Survey reveals Zero Trust adoption appealing but challenging." *intelligentcio.com*. Accessed: Nov. 26, 2022 [Online]. Available: <https://www.intelligentcio.com/north-america/2021/09/16/survey-reveals-zero-trust-adoption-appealing-but-challenging/>
- 3 K.D. Uttecht, "Zero Trust (ZT) Concepts for Federal Government Architectures," Lincoln Laboratory, Massachusetts Institute of Technology, Lexington, Massachusetts, USA, 2020. [Online]. Available: <https://apps.dtic.mil/sti/pdfs/AD1108910.pdf>
- 4 S. Teerakanok, T. Uehara, and A. Inomata, "Migrating to Zero Trust Architecture: Reviews and Challenges," *Security and Communication Networks*, vol. 2021, pp. 1–10, May 2021, doi: 10.1155/2021/9947347.
- 5 K. E. Foltz and W. R. Simpson, "Zero Trust Technology Integration Issues." Institute for Defense Analyses, VA, USA, 2021. [Online]. Available: <https://www.jstor.org/stable/resrep34846>
- 6 E. Gilman and D. Barth. *Zero trust networks*. Sebastopol, CA, USA: O'Reilly Media, 2017.
- 7 S. Barracuda. "What is a Network Perimeter?." Accessed: Dec. 10, 2022 [Online]. Available: <https://www.barracuda.com/glossary/network-perimeter>.
- 8 G. UÇTU, M. ALKAN, İ. A. Doğru and M. Dörterler, "Perimeter Network Security Solutions: A Survey," *2019 3rd International Symposium on Multidisciplinary Studies and Innovative Technologies (ISMSIT)*, 2019, pp. 1-6, doi: 10.1109/ISMSIT.2019.8932821.

- 9 Perez-Etchegoyen, J. "8 Reasons Perimeter Security Alone Won't Protect Your Crown Jewels." Accessed: Dec. 10, 2022. [Online]. Available: <https://www.darkreading.com/cloud/8-reasons-perimeter-security-alone-won-t-protect-your-crown-jewels>
- 10 S. Cyolo Team. "Why Perimeter Security Is No Longer Enough." Accessed: Dec. 10, 2022. [Online]. Available: <https://cyolo.io/blog/why-perimeter-security-is-no-longer-enough/>
- 11 I. Ahmed, T. Nahar, S.S. Urmi, and K. A. Taher, "Protection of Sensitive Data in Zero Trust Model" In *Proceedings of the International Conference on Computing Advancements*, 2020, pp. 1–5, doi: 10.1145/3377049.3377114
- 12 A. Wylde, "Zero trust: Never trust, always verify," *2021 International Conference on Cyber Situational Awareness, Data Analytics and Assessment (CyberSA)*, 2021, pp. 1-4, doi: 10.1109/CyberSA52016.2021.9478244.
- 13 S. Rose, O. Borchert, S. Mitchell and S. Connelly, "NIST special publication 800–207 zero trust architecture," National Institute of Standards and Technology, US Department of Commerce, 800-207, 2020. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-207.pdf>
- 14 K. Raina. "Zero Trust Security Explained: Principles of The Zero Trust Model." Accessed: Dec. 10, 2022. [Online]. Available: <https://www.crowdstrike.com/cybersecurity-101/zero-trust-security/>
- 15 B. Embrey. "The top three factors driving zero trust adoption," *Computer Fraud&Security*, vol. 2020, pp. 13–15, Jan. 2020, doi: 10.1016/S1361-3723(20)30097-X.
- 16 R. Ward and B. Beyer. "BeyondCorp: a new approach to enterprise security," *login:*, vol. 39, no. 6, pp. 6–11, Dec. 2014. Available: https://www.usenix.org/system/files/login/articles/login_dec14_02_ward.pdf
- 17 Axiad. "What Are the Disadvantages of Zero Trust? (And How to Overcome Them)." Axiad, USA, 2022. Accessed: Jan. 11, 2023. [Online]. Available: <https://www.axiad.com/blog/what-are-the-disadvantages-of-zero-trust-and-how-to-overcome-them/>

- 18 J. Michael, G. Dinolt, and F. Cohen, "Can You Trust Zero Trust," *Computer*, vol. 55, issue.8, pp. 103–105, Aug 2022, doi: 10.1109/MC.2022.3178813.
- 19 C. Cunningham and S. Turner. "The Zero Trust eXtended (ZTX) ecosystem," Forrester Research, Inc., Cambridge, MA, USA, Aug. 2021.
- 20 Microsoft. "Implementing a Zero Trust security model at Microsoft," microsoft.com. Accessed: Nov. 27, 2022. [Online]. Available: <https://www.microsoft.com/en-us/insidetrack/implementing-a-zero-trust-security-model-at-microsoft>
- 21 S. Turner *et al.*, "A Practical Guide To A Zero Trust Implementation," Forrester Research, Inc., Cambridge, MA, USA, Mar. 2021.
- 22 M. J. Haber, *Privileged Attack Vectors: building effective cyber-defense strategies to protect organizations*. 2nd ed. New York City, NY, USA: Apress, 2020.
- 23 E. Bertino and K. Brancik, "Services for Zero Trust Architectures - A Research Roadmap," *2021 IEEE International Conference on Web Services (ICWS)*, 2021, pp. 14–20, doi: 10.1109/ICWS53863.2021.00016.
- 24 J. Garbis and J. W. Chapman. *Zero Trust Security: An Enterprise Guide*. 1st ed. New York City, NY, USA: Apress, 2021.
- 25 M. J. Page *et al.*, "The PRISMA 2020 statement: an updated guideline for reporting systematic reviews.," *Syst Rev*, vol. 10, no. 89, Mar. 2021, doi: 10.1186/s13643-021-01626-4.
- 26 V. Garousi, M. Felderer, and M. V. Mäntylä, "Guidelines for including grey literature and conducting multivocal literature reviews in software engineering," *Information and Software Technology*, vol. 106, pp. 101–121, Feb. 2019, doi: 10.1016/j.infsof.2018.09.006.
- 27 V.J. Mabin *et al.*, "Harnessing resistance: using the theory of constraints to assist change management," *Journal of European Industrial Training*, vol. 25, no. 2/3/4, pp.168-191, doi: 10.1108/EUM0000000005446.
- 28 K. Batti. "7 Best Practices in Change Management Communication." Accessed: Dec. 12, 2022. [Online]. Available: <https://www.actiac.org/documents/zero-trust-cybersecurity-current-trends>
- 29 J. Miranda *et al.*, "Identifying adaptation needs to avoid the vendor lock-in effect in the deployment of cloud SBAs," *Proceedings of the 2nd International*

- Workshop on Adaptive Services for the Future Internet and 6th International Workshop on Web APIs and Service, pp. 12–19, Sep. 2012, doi: 10.1145/2377836.2377841.
- 30 B. Osborn, J. McWilliams, B. Beyer and M. Saltonstall. “BeyondCorp: design to deployment at Google,” *login*, vol. 41, no. 1, pp. 28–34, 2016. Available: https://www.usenix.org/system/files/login/articles/login_spring16_06_osborn.pdf
- 31 M. Fahmideh, F. Gholami, F. Daneshgar, G. Low, and G. Beydoun, “Cloud migration process—A survey, evaluation framework, and open challenges,” *Journal of Systems and Software*, vol. 120, pp. 31–69, Oct. 2016, doi: 10.1016/j.jss.2016.06.068.
- 32 J. Münch (ed.). “Data-and Value-Driven Software Engineering with Deep Customer Insight: Proceedings of the Seminar No. 58314308,” *University of Helsinki, Department of Computer Science*, 2014. Available: <http://hdl.handle.net/10138/152785>
- 33 S. Badshah, A.A. Khan, and B. Khan. “Towards process improvement in DevOps: a systematic literature review,” *Proceedings of the evaluation and assessment in software engineering*, pp.427–433, 2020, doi: 10.1145/3383219.3383280.
- 34 P. Jha and R. Khan. (2018). “A review paper on DevOps: Beginning and more to know,” *International Journal of Computer Applications*, vol. 180, no. 48, pp.16–20, 2018, doi: 10.5120/ijca2018917253.
- 35 Hitachi ID Systems, Inc., “Zero Trust and Access Management: A Journey, Not a Destination,” Hitachi ID Systems, Inc., Calgary, Alberta, Canada, 2021.
- 36 ILLUMIO. “Achieving Zero Trust With ILLUMIO,” Illumio, Inc., Sunnyvale, CA, USA, 2020. [Online]. Available: <https://www.illumio.com/sites/default/files/2021-02/achieving-zero-trust-20sb10%20%281%29.pdf>
- 37 Microsoft. “Zero Trust Business Plan – Microsoft,” *microsoft.com*. Accessed: Nov. 27, 2022. [Online] Available: <https://query.prod.cms.rt.microsoft.com/cms/api/am/binary/RWJtxq>

- 38 Palo Alto Networks. "Best Practices Implementing Zero Trust with Palo Alto Networks," Palo Alto Networks, Inc., 2022. [Online]. Available: https://docs.paloaltonetworks.com/content/dam/techdocs/en_US/pdf/best-practices/zero-trust-best-practices/zero-trust-best-practices.pdf
- 39 L. Cittadini, B. Spear, B. Beyer, and M. Saltonstall. "BeyondCorp: The Access Proxy," *login*, vol. 41, no. 4, 2016. Available: https://www.usenix.org/system/files/login/articles/login_winter16_05_cittadini.pdf
- 40 J. Budge and C. Cunningham. "How To Implement Zero Trust Security In Asia Pacific," Forrester Research, Inc., Cambridge, MA, USA, Oct. 2020.
- 41 Y. Bobbert and J. Scheerder. "On the design and engineering of a zero trust security artefact," *Future of Information and Communication Conference*, 2021, pp. 830–848, doi: 10.1007/978-3-030-73100-7_58.
- 42 Y. J. Peck, B. Beyer, C. Beske, and M. Saltonstall. "Migrating to BeyondCorp: maintaining productivity while improving security," *login*, vol. 42, no. 2, 2017. Available: https://www.usenix.org/system/files/login/articles/login_summer17_10_peck.pdf
- 43 T. M. S. do Amaral and J. J. C. Gondim, "Integrating Zero Trust in the cyber supply chain security," *2021 Workshop on Communication Networks and Power Systems (WCNPS)*, 2021, pp. 1–6, doi: 10.1109/WCNPS53648.2021.9626299.
- 44 E. Bertino and K. Brancik, "Services for Zero Trust Architectures - A Research Roadmap," *2021 IEEE International Conference on Web Services (ICWS)*, 2021, pp. 14–20, doi: 10.1109/ICWS53863.2021.00016.
- 45 C. Gero. "A Blueprint for Zero Trust Architecture: Actionable Implementation Guide," Akamai Technologies, Inc., Cambridge, MA, USA, 2021. [Online]. Available: <https://www.intelligentcio.com/me/wp-content/uploads/sites/12/2022/05/A-Blueprint-for-Zero-Trust-Architecture-WP.pdf>
- 46 PricewaterhouseCoopers. "Zero Trust architecture: a paradigm shift in cybersecurity and privacy," PricewaterhouseCoopers Consulting (Singapore) Pte. Ltd., Singapore, 2021. [Online]. Available:

- <https://www.pwc.com/sg/en/publications/assets/page/zero-trust-architecture.pdf>
- 47 CISCO. “From MFA to Zero Trust: A Five-Phase Journey to Securing the Federal Workforce,” CISCO SECURE, White Paper, 2021. Accessed: Nov. 25, 2022 [Online]. Available: <https://www.meritalk.com/wp-content/uploads/2021/06/mfa-to-zero-trust.pdf>
- 48 D. Klein, “Micro-segmentation: securing complex cloud environments,” *Network Security*, vol. 2019, no. 3, pp. 6–10, Mar. 2019, doi: 10.1016/s1353-4858(19)30034-0.
- 49 R. Mass. “A hands-on approach to Zero Trust implementation,” ON2IT, Gelderland, Netherlands, 2020. [Online]. Available: <https://www.cymbel.com/wp-content/uploads/2020/10/A-hands-on-approach-to-Zero-Trust-implementation.pdf>
- 50 V.M. Escobedo, F. Zyzniewski and M. Saltonstall. “BeyondCorp: the user experience,” *login.*, vol. 42, no. 3, pp. 6–11, 2017. Available: https://www.usenix.org/system/files/login/articles/login_fall17_08_escobedo.pdf
- 51 H. King, M. Janosko, B. Beyer, and M. Saltonstall. “BeyondCorp: Building a Healthy Fleet” *login.*, vol. 43, no. 3, 2018. Available: https://www.usenix.org/system/files/login/articles/login_fall18_05_king.pdf
- 52 S. Mehraj and M. T. Banday, “Establishing a Zero Trust Strategy in Cloud Computing Environment,” *2020 International Conference on Computer Communication and Informatics (ICCCI)*, Coimbatore, India, 2020, pp. 1-6, doi: 10.1109/ICCCI48352.2020.9104214.
- 53 T. Li, M. Evans, and D. Jones, “Zero Trust in the Cloud: How Could Migration Can Create Opportunities for Cyber Security,” Deloitte Development LLC., Hermitage, TN, USA, 2022. [Online]. Available: <https://www2.deloitte.com/content/dam/Deloitte/us/Documents/public-sector/us-gps-zero-trust-article-v1.pdf>



APPENDIX A

QUALITY ASSESSMENT CHECKLIST OF GREY LITERATURE FOR SOFTWARE ENGINEERING

Table A-1: Quality assessment checklist of grey literature for software engineering [24]

Criteria	Questions
Authority of the producer	• Is the publishing organization reputable? • Is an individual author associated with a reputable organization? • Has the author published other work in the field? • Does the author have expertise in the area?
Methodology	• Does the source have a clearly stated aim? • Does the source have a stated methodology? • Is the source supported by authoritative, contemporary references? • Are any limits clearly stated? • Does the work cover a specific question? • Does the work refer to a particular population or case?
Objectivity	• Does the work seem to be balanced in presentation? • Is the statement in the sources as objective as possible? Or, is the statement a subjective opinion? • Is there vested interest? E.g., a tool comparison by authors that are working for particular tool vendor • Are the conclusions supported by the data?
Date	• Does the item have a clearly stated date?
Position w.r.t. related sources	• Have key related GL or formal sources been linked to / discussed?
Novelty	• Does it enrich or add something unique to the research? • Does it strengthen or refute a current position?
Impact	• Normalize all the following impact metrics into a single aggregated impact metric (when data are available): Number of citations, Number of backlinks, Number of social media shares (the so-called “alt metrics”), Number of comments posted for a specific online entry like a blog post or a video, Number of page or paper views
Outlet type	• 1st tier GL (measure=1): High outlet control/ High credibility: Books, magazines, theses, government reports, white papers

APPENDIX B

STUDIES OBTAINED FOR FINAL REVIEW

Table B-1: Identification of Studies via Academic Database

Study	Author	Year	Title	Published in	Publication Type	Classification into Process	Framework Code
[S1]	I. Ahmed, T. Nahar, S.S. Urmi, and K. A. Taher	2020	Protection of Sensitive Data in Zero Trust Model	ICCA 2020: International Conference on Computing Advancements	Conference Paper	II – Context Assessment V – Monitoring and Maintenance	[A1]
[S2]	T. M. S. do Amaral and J. J. C. Gondim	2021	Integrating Zero Trust in the cyber supply chain security	2021 Workshop on Communication Networks and Power Systems (WCNPS)	Conference Paper	II – Context Assessment III – Architect ZTA	[A2]
[S3]	E. Bertino and K. Brancik	2021	Services for Zero Trust Architectures - A Research Roadmap	2021 IEEE International Conference on Web Services (ICWS)	Conference Paper	II – Context Assessment	[A3]
[S4]	D. Tyler and T. Viana	2021	Trust No One? A Framework for Assisting Healthcare Organisations in Transitioning to a Zero-Trust Network Architecture	MDPI	Journal Paper	IV – Zero Trust Transformations	[A4]
[S5]	S. Teerakanok, T. Uehara, and A. Inomata	2021	Migrating to Zero Trust Architecture: Reviews and Challenges	Hindawi: Security and Communication Networks	Journal Paper	II – Context Assessment	[A5]

Study	Author	Year	Title	Published in	Publication Type	Classification into Process	Framework Code
[S6]	D. Klein	2019	Micro-segmentation: securing complex cloud environments	ELSEVIER: Network Security Volume 2019, Issue 3	Journal Paper	III – Architect ZTA	[A6]
[S7]	Y. Bobbert and J. Scheerder	2021	On the Design and Engineering of a Zero Trust Security Artefact	FICC 2021: Advances in Information and Communication	Conference Paper	I – Strategize Zero Trust	[A7]
[S8]	J. Garbis and J. W. Chapman	2021	Zero Trust Security: An Enterprise Guide	Apress; 1st ed. edition	Book	I – Strategize Zero Trust II – Context Assessment IV – Zero Trust Transformations	[A8]
[S9]	M. J. Haber	2021	Privileged Attack Vectors: Building Effective Cyber-Defense Strategies to Protect Organizations	Apress; 2nd ed. edition	Book	II – Context Assessment III – Architect ZTA V – Monitoring and Maintenance VI – Optimize ZTA Security	[A9]

Table B-2: Identification of Studies via Other Methods

Study	Author	Year	Title	Publisher	Classification into Process	Framework Code
[S10]	S. Rose, O. Borchert, S. Mitchell and S. Connelly	2021	NIST Special Publication 800-207: Zero Trust Architecture	National Institute of Standards and Technology	I – Strategize Zero Trust II – Context Assessment III – Architect ZTA IV – Zero Trust Transformations	[A10]
[S11]	R. Ward and B. Beyer.	2014	BeyondCorp: A New Approach to Enterprise Security	Google Research	III – Architect ZTA IV – Zero Trust Transformations	[A11]
[S12]	L. Cittadini, B. Spear, B. Beyer, and M. Saltonstall	2016	BeyondCorp: The Access Proxy	Google Research	I – Strategize Zero Trust	[A11]
[S13]	B. Osborn, J. McWilliams, B. Beyer and M. Saltonstall	2016	BeyondCorp: design to deployment at Google	Google Research	IV – Zero Trust Transformations	[A11]
[S14]	H. King, M. Janosko, B. Beyer, and M. Saltonstall	2018	BeyondCorp: Building a Healthy Fleet	Google Research	IV – Zero Trust Transformations	[A11]
[S15]	J. Peck, B. Beyer, C. Beske, and M. Saltonstall	2017	Migrating to BeyondCorp: maintaining productivity while improving security	Google Research	I – Strategize Zero Trust IV – Zero Trust Transformations	[A11]
[S16]	V.M. Escobedo, F. Zyzniewski and M. Saltonstall	2017	BeyondCorp: the user experience	Google Research	IV – Zero Trust Transformations	[A11]
[S17]	Microsoft	2021	Implementing a Zero Trust security model at Microsoft	Microsoft	II – Context Assessment III – Architect ZTA	[A12]
[S18]	Microsoft	2020	Zero Trust Business Plan – Microsoft	Microsoft	I – Strategize Zero Trust V – Monitoring	[A12]

Study	Author	Year	Title	Publisher	Classification into Process	Framework Code
					and Maintenance	
[S19]	ILLUMIO	2019	Achieving Zero Trust With ILLUMIO	Illumio	I – Strategize Zero Trust III – Architect ZTA V – Monitoring and Maintenance	[A13]
[S20]	Palo Alto Networks	2020	Best Practices Implementing Zero Trust with Palo Alto Networks	Palo Alto Networks	I – Strategize Zero Trust II – Context Assessment III – Architect ZTA IV – Zero Trust Transformations V – Monitoring and Maintenance VI – Optimize ZTA Security	[A14]
[S21]	Pricewaterhouse Coopers	2021	Zero Trust architecture: a paradigm shift in cybersecurity and privacy	Pricewaterhouse Coopers Consulting Pte. Ltd.	II – Context Assessment III – Architect ZTA V – Monitoring and Maintenance VI – Optimize ZTA Security	[A15]
[S22]	S. Turner, et al.	2021	A Practical Guide To A Zero Trust Implementation	Forrester Research	I – Strategize Zero Trust II – Context Assessment III – Architect ZTA	[A16]
[S23]	J. Budge and C. Cunningham	2020	How To Implement Zero Trust Security In Asia Pacific	Forrester Research	I – Strategize Zero Trust	[A16]
[S24]	CISCO	2021	From MFA to Zero Trust: A Five-Phase Journey to Securing the Federal Workforce	Duo Security, Inc.	III – Architect ZTA	[A17]
[S25]	C. Gero	2021	A Blueprint for Zero Trust Architecture: Actionable Implementation Guide	Akamai Technologies	II – Context Assessment IV – Zero Trust Transformations VI – Optimize ZTA Security	[A18]

Study	Author	Year	Title	Publisher	Classification into Process	Framework Code
[S26]	K. Uttecht	2020	Zero Trust (ZT) Concepts for Federal Government Architectures	MIT Lincoln Laboratory	I – Strategize Zero Trust III – Architect ZTA IV – Zero Trust Transformations	[A19]
[S27]	HITACHI	2021	Zero Trust and Access Management: A Journey, Not a Destination	Hitachi ID Systems, Inc.	I – Strategize Zero Trust III – Architect ZTA	[A20]
[S28]	ON2IT	2020	A hands-on approach to Zero Trust implementation	ON2IT	III – Architect ZTA V – Monitoring and Maintenance	[A21]

Table B-3: Main Concepts of Obtained Studies

Study	Author	Main Concept
[S1]	I. Ahmed, T. Nahar, S.S. Urmi, and K. A. Taher (2020)	The study describes the basic steps of Zero Trust implementation. The steps include identifying and mapping sensitive data flows, architecting the parameters of Zero Trust, and monitoring the Zero Trust ecosystem. The final step is to adopt security automation and orchestration.
[S2]	T. M. S. do Amaral and J. J. C. Gondim	The study aims to provide security controls based on ZTA's principles. The security controls apply to five domains: device, identity, application, governance and data, infrastructures, and networks.
[S3]	E. Bertino and K. Brancik (2021)	The study demonstrates concepts of a ZT model implementation. An enterprise must know about threats and select appropriate ZTA service providers. After implementation, the implementation solutions should be measured against performance metrics.
[S4]	D. Tyler and T. Viana (2021)	This study provides technical concepts on implementing ZTA starting from the stage of implementing basic security, logging, and monitoring the network. The next stage is to implement micro-segmentation and apply further access control.
[S5]	S. Teerakanok, T. Uehara, and A. Inomata (2021)	This study explains three main steps of migration starting from an assessment stage where the actors and assets of an enterprise are identified. The next step is undertaking risk assessment and prioritization to identify low-risk candidates for the first transition. The final step is deploying and reviewing the migration process.
[S6]	D. Klein (2019)	The study describes essential phases of implementing micro-segmentation, starting from the discovery and identification of all applications, and then mapping dependencies. The next phase is grouping applications for rules and creating policies. The next stage is to deploy, monitor, and enforce

Study	Author	Main Concept
		those policies.
[S7]	Y. Bobbert and J. Scheerder (2021)	This study focuses on creating three levels of plans for ZTA migration. First, an enterprise must establish a strategic plan to understand the environment and capabilities. Second, a managerial plan should be created to know potential risks. Finally, an operational plan should also be created to determine ZT technologies.
[S8]	J. Garbis and J. W. Chapman (2021)	The deployment begins by defining problems, researching ZT solutions, and proposing potential implementation approaches. After that, the migration team performs proof of concept of potential ZT platforms in a non-production environment. Once a pilot instance is successfully deployed, the team can deploy a pilot program in production and validate the results.
[S9]	M. J. Haber (2021)	There are key migration steps, starting from defining sensitive data and mapping the processes of those sensitive data. Then, an enterprise creates the micro-perimeter and monitors the Zero Trust environment. Finally, an enterprise adopts automation and adaptive response.
[S10]	S. Rose, O. Borchert, S. Mitchell and S. Connelly (2021)	This study provides an incremental change approach to the ZTA migration. An enterprise must survey assets and examine and map the business process. Then an enterprise chooses the candidate workflow for initial deployment. The next phase is to extend the ZT deployment.
[S11]	R. Ward and B. Beyer (2014)	The study explains the strategy of implementing ZTA. The significant implementation concerns include identifying the device and user and removing trust from the network. Moreover, an enterprise externalizes applications and workflows and deploys inventory-based access control.
[S12]	L. Cittadini, B. Spear, B. Beyer, and M. Saltonstall (2016)	This study provides methods to handle exceptional cases and exceptions for transitioning to ZTA. In addition, the study emphasizes the importance of coordination and integration of multiple teams for migration.
[S13]	B. Osborn, J. McWilliams, B. Beyer and M. Saltonstall (2016)	The study explains the methods to deploy the initial rollout of the candidate workflows. The focus is to deploy ZTA without user disruptions and provide a method for users to be self-remediate.
[S14]	H. King, M. Janosko, B. Beyer, and M. Saltonstall (2018)	The study describes an approach to handle exceptions for the ZT project. An enterprise should determine procedures and technical implementation for exception management.
[S15]	J. Peck, B. Beyer, C. Beske,	The study shows how to roll out the ZT migration in phases. The pilot program begins to roll out in a small-scale pilot. The rollout increases over

Study	Author	Main Concept
	and M. Saltonstall (2017)	time and expands to the risky workflows after learning from a history of success and gaining more confidence in the strategy.
[S16]	V.M. Escobedo, F. Zyzniowski and M. Saltonstall (2017)	The study emphasizes the importance of communicating with users regarding ZTA early. Moreover, new devices will be set up and automatically configured to access the ZT environment. In addition, the study explains the methods to reduce VPN usage.
[S17]	Microsoft (2021)	Four primary services need to be verified for implementation. An enterprise must verify the identity of users and register devices into the device management system. In addition, the access must be verified to segment users and devices. Finally, the services must be verified to enable conditional access.
[S18]	Microsoft (2020)	The study describes two main stages of migrating to ZTA. First, the planning stage involves defining a vision, getting buy-in from stakeholders, and defining the scope of implementation. In the measurement stage, an enterprise should measure security effectiveness after successfully implementing ZTA.
[S19]	ILLUMIO (2019)	The essential steps to migrate to ZTA are as follows. 1) an enterprise defines a vision with key stakeholders. 2.) Identifying and mapping data flows. 3) implementing micro-segmentation. 4) mitigating vulnerabilities and prioritizing risks. 5) automation and orchestration security processes.
[S20]	PaloAlto Networks (2020)	There are five main steps of implementing ZTA. 1) an enterprise defines the protected surface. 2) The protected surface is mapped to transaction flows. 3) an enterprise architects a ZT network 4) The ZT policies are created. Finally, 5) an enterprise monitor and maintain the ZT network.
[S21]	Pricewaterhouse Coopers (2021)	The study describes five main steps of migrating to ZTA. 1) identifying sensitive data 2) Defining sensitive data flows 3) Defining micro-perimeter network 4) Creating security policies and control framework. 5) Continuously monitoring the ZT network.
[S22]	S. Turner, et al. (2021)	The study shows a practical guide to implementing ZTA. The first step is to perform program mobilization to establish the ZT project plans. The next step is implementing the ZT solutions to protect users, devices, workloads, and networks.
[S23]	J. Budge and C. Cunningham (2020)	The study focuses on defining key stakeholders in implementing ZTA. The key stakeholders concern many teams in an enterprise, such as the management, audit and compliance team, operational team, and security team.
[S24]	CISCO (2021)	The study shows five phases of implementing ZTA. Phase 1 is to establish user trust and Phase 2 is to implement device and activity visibility. At phase 3, it is to establish device trust. Phase 4 creates adaptive policies,

Study	Author	Main Concept
		and phase 5 utilizes Zero Trust for the federal workforce.
[S25]	C. Gero (2021)	The study describes three main stages of the ZTA migration, starting from the planning stage for the ZT. The second stage is to perform user grouping for the migration. The next stage is to deploy the application rollout for ZTA.
[S26]	K.D. Uttecht (2020)	The study describes essential methods for migrating to ZTA. Firstly, an enterprise must have a clear plan for the ZT project and get stakeholder buy-in. Then, the enterprise gathers information about assets and creates use cases of how ZT will be implemented.
[S27]	HITACHI (2021)	The study describes critical steps to migrate to ZTA, starting from gaining leadership and stakeholders' support. The next step is to select the ZT migration team and assess the current environment. The next phase is to review the available ZT technologies, plan the ZT activities, and identify operational changes.
[S28]	ON2IT (2020)	The study explains five main steps to migrating to ZTA. 1) Define and classify the protected surface 2) Map the transaction flows 3) Architect a ZT network 4) Establish the ZT policies 5) Monitor and maintain the ZT network.

APPENDIX C

ZERO TRUST ARCHITECTURE (ZTA) MIGRATION CHECKLIST

This document is a guideline that intends to assist an organization planning to migrate to ZTA in establishing a common process of implementing ZTA in their organizational context. The purpose of this guideline is to provide checklists that an organization can consider and prepare in order to migrate successfully to ZTA. This guideline comprises two following parts:

1. ZTA Migration Process Checklist
2. ZTA Security Domains Checklist

1. ZTA Migration Process Checklist

Instruction: There is a choice of responses for each question to indicate the status of your readiness and preparation for ZTA migration.

For each question, only one response should be chosen.

The table below contains a description of the meaning of each response:

Response	When to use
Yes	You have verified and conformed to the recommendation.
Part	You have partially verified and conformed to the recommendation.
No	You do not verify and conform to the recommendation.
N/A (Not Applicable)	The recommendation does not apply to you.

Process	Sub-Process	Question(s)	Control(s)	Response			
				Yes	Part	No	N/A
1. Strategize Zero Trust	1.1 Create Zero Trust Strategy	1.1.1 Have you defined vision and strategies to achieve ZTA migration?	1.1.1.1 We have identified vision and strategies for ZTA migration.				
		1.1.2 Does ZTA migration strategies gain support from stakeholders?	1.1.2.1 ZTA migration strategies have been supported and approved by management.				
			1.1.2.2 ZTA migration strategies have been communicated and gain support from stakeholders such as users, IT teams, Operation teams				
	1.2 Set up Zero Trust Teams	1.2.1 Have the key decision-makers to provide direction of ZTA migration been established?	1.2.1.1 We have established the key decision-makers e.g., governance board, architecture review board, and change management board.				
			1.2.2.1 We have set up the ZT migration team members.				
		1.2.2 Have the ZT implementation team been established?	1.2.2.2 We have appropriately selected cross-functional team members concerning application and data security, network and infrastructure security, and user and device identity.				

Process	Sub-Process	Question(s)	Control(s)	Response			
				Yes	Part	No	N/A
2. Context Assessment	2.1 Assess the Current States	2.1.1 Have you evaluated your current security controls?	2.1.1.1 We have checked and monitored existing security policies that are compatible with Zero Trust principles.				
			2.1.1.2 We have checked integration and interoperability of existing systems, including legacy systems.				
		2.1.2 Have you performed security risk assessment?	2.1.2.1 We have performed security risk assessment and identify potential risks and threats.				
		2.1.3 Have you performed ZT maturity assessment?	2.1.3.1 We have conducted ZT maturity assessment and set desired maturity state.				
			2.1.3.2 We have set objectives and time frame to achieve the target ZT maturity state.				
	2.2 Perform Resource Discovery	2.2.1 Have you performed or surveyed the protected surface of all resources?	2.2.1.1 We have identified sensitive data, assets, and business process flows.				
			2.2.1.2 We have mapped the protected surface with the business workflows to understand interdependencies.				

Process	Sub-Process	Question(s)	Control(s)	Response			
				Yes	Part	No	N/A
3. Architect ZTA	3.1 Create a ZT Migration Plan	3.1.1 Have you created a ZTA migration plan?	3.1.1.1 We have created a ZTA migration plan to divide and prioritize tasks for implementation.				
			3.1.1.2 We have created test plans and performance measurement plans for ZTA implementation.				
		3.1.2 Have you survey the available zero trust solutions and technologies?	3.1.2.1 We have survey and select appropriate vendors providing zero trust solutions that meet requirements.				
			3.1.2.2 We have considered software and systems interoperability concerning vendor lock-in effects.				
	3.2 Preparation of Device, User and Network *	3.2.1 Have you prepared each ZT security domain solutions for implementation?	3.2.1.1 We have prepared systems and technologies concerning identity security.				
			3.2.1.2 We have systems and technologies concerning device security.				
			3.2.1.3 We have prepared systems and technologies concerning data security.				
			3.2.1.4 We have prepared systems and				

Process	Sub-Process	Question(s)	Control(s)	Response			
				Yes	Part	No	N/A
			technologies concerning network security.				
			3.2.1.5 We have prepared systems and technologies concerning workloads security.				
			3.2.1.6 We have prepared systems and technologies concerning visibility and analytics.				
			3.2.1.7 We have prepared ZT security domain concerning automation and orchestration.				
	3.3 Design Zero Trust Policy	3.3.1 Have you designed or established zero trust policy?	3.3.1.1 I have created appropriate zero trust policies based on resources and transaction flows.				
			3.3.1.2 I have ensured that the zero trust policies are not duplicated and redundant.				
			3.3.1.3 We have tested and redefined zero trust policies.				
4. Zero Trust Transformation	4.1 A Pilot Program to A Full Production Method	4.1.1 Have you identified potential group of candidates that has low	4.1.1.1 We have identified the group of candidates that has low risks for migration.				

Process	Sub-Process	Question(s)	Control(s)	Response			
				Yes	Part	No	N/A
		risk for the migration?					
		4.1.2 Do you provide method for users who request temporary exemptions for the migration?	4.1.2.1 We have provided methods and solutions for users who request temporary exemptions.				
	<i>Phase 1: Production Pilot</i>	4.1.3 Can you employ the unprivileged network simulation to simulate network behavior and monitor network traffic for pilot production?	4.1.3.1 We have employed the unprivileged network simulation to simulate network behavior and monitor network traffic.				
			4.1.3.2 We have prepared channels to switch back to the old systems if needed.				
	<i>Phase 2: Validate Pilot Results</i>	4.1.4 Have you validated pilot results to ensure the qualified traffic can be assign to the unprivileged network?	4.1.4.1 We have validated pilot results and ensure the qualified traffic can be assign to the unprivileged network.				
	<i>Phase 3: Full Production Rollout</i>	4.1.5 Can you continue to deploy the remaining groups of users from the test environment to the production?	4.1.5.1 We can continue to deploy the remaining groups of users from the test environment to the production.				
		4.1.6 Can you decommission the old technologies and fully enforce ZT platform?	4.1.6.1 We can decommission the old technologies and fully enforce ZT platform.				

Process	Sub-Process	Question(s)	Control(s)	Response			
				Yes	Part	No	N/A
	4.2 Measure Implementation Success & Error Remediation	4.2.1 Have you evaluated test plans and implementation metrics of the ZTA implementation?	4.2.1.1 We have assessed the test plans and implementation metrics of the ZTA implementation.				
		4.2.2 Do you have methods or channels to handle error remediation of users?	4.2.2.1 We have provided methods and channels to handle error remediation of users.				
		4.2.3 Have you promoted and communicated the success of the ZTA migration project?	4.2.3.1 We have promoted and communicated the success of the ZTA migration project.				
5. Monitoring & Maintenance	5.1 Monitor ZT Ecosystem	5.1.1 Can you inspect and log all network traffic in real-time to gain visibility of users and network activities?	5.1.1.1 We can inspect and log all network traffic in real-time to gain visibility of users and network activities.				
		5.1.2 Can you continuously monitor ZTA with security analytics tools?	5.1.2.1 We can use security analytics tools to continuously monitor ZTA.				
	5.2 Measure Security Effectiveness	5.2.1 Have you measured security effectiveness after successfully implementing ZTA?	5.2.1.1 We have measured security effectiveness such as user experience, frictions, interruptions, and security incidents.				

Process	Sub-Process	Question(s)	Control(s)	Response			
				Yes	Part	No	N/A
6. Optimize ZTA Security	6.1 Zero Trust Performance Upgrade Plan	6.1.1 Do you have plan to upgrade the Zero Trust security performance?	6.1.1.1 I have set up the plan to upgrade the Zero Trust security performance.				
	6.2 Adoption of Security Automation and Orchestration	6.2.1 Do you have manual security operations and procedures that you plan to translate them to technology automation?	6.2.1.1 We have manual security operations and procedures planning to translate them to technology automation.				
		6.2.2 Have you integrated SOAR (security orchestration, automation, and response) to improve ZTA security automation and orchestration?	6.2.2.1 We have integrated SOAR to improve ZTA security automation and orchestration.				

Note:

.....

.....

.....

.....

.....

.....

* You should complete *ZTA Security Domains Checklist* before answer your response.

2. ZTA Security Domains Checklist

Instruction: This ZTA security domains checklist can be used to plan and check the technical design of your ZTA model. You should indicate your systems or solutions currently employed in your IT environment and assess whether you should upgrade or replace them to work efficiently in the ZT environment. You may see the suggestion for systems or solutions for each security domain.

Domain	Question	Current Solution	Future Solution (Required Upgrade/Replacement)	Note
Identity	- What are methods or solutions to verify users who they claim they are? - Are you using a scalable identity and assessment management solution?	<i>(E.g., Password-based solution, Multi-Factor Authentication (MFA), Two-factor authentication (2FA), Biometric-based authentication, Risk-based authentication)</i>	☐ Yes / ☐ No	
Device	- Can you check or track the security posture of all devices both corporate and BYOD devices? - Do you have information of device accessing to your services or applications?	<i>(E.g., Device inventory database, Device asset management, Endpoint detection and response (EDR), Mobile device management (MDM))</i>	☐ Yes / ☐ No	

Domain	Question	Current Solution	Future Solution (Required Upgrade/Replacement)	Note
Data	• Do you have methods or mechanisms to ensure data remains safe while data is in use, in transit, or at rest? • Do you have methods or solutions to ensure data is safeguard from leakage, tampering and eavesdropping?	<i>(E.g., Data security, Data encryption, Data discovery and classification, Data loss prevention)</i>	☐ Yes / ☐ No	
Network	• Can you control, segment and isolate network to ensure user legitimate access? • Are you using a scalable network infrastructure or solutions to control, segment or isolate network? • Do you have network visibility to monitor and detect potential threats?	<i>(E.g., Network Security, Network segmentation, Software-defined networking, Network firewalls, Network Access Control, IDS/IPS)</i>	☐ Yes / ☐ No	

Domain	Question	Current Solution	Future Solution (Required Upgrade/Replacement)	Note
Workloads	Do you have mechanisms or solutions to protect connections of services, programs, and applications running on premises and in the cloud?	<i>(E.g., Workload asset management, Cloud workload security, Web application firewall (WAF), cloud access security broker (CASB), VM and container security configuration)</i>	☐ Yes / ☐ No	
Visibility & Analytics	- Do you have tools or systems that can monitor, collect and analyze security activities? - Can visibility and analytics tools work together or work in isolation?	<i>(E.g., Threat Intelligence, Security Information and Event Management (SIEM), Continuous Diagnostics and Mitigation (CDM))</i>	☐ Yes / ☐ No	

Domain	Question	Current Solution	Future Solution (Required Upgrade/Replacement)	Note
Automation & Orchestration	Do you have the technologies or systems that can provide automation and orchestration functions among many security components of ZTA?	<i>(E.g., SOAR (security orchestration, automation, and response), Policy Enforcement Point (PEP), Policy Administrator (PA), Policy Engine (PE), Security Policy Management)</i>	☐ Yes / ☐ No	

BIOGRAPHY

NAME	Pacharee Phiayura
DATE OF BIRTH	June 14, 1990
PLACE OF BIRTH	Khon Kaen, Thailand
INSTITUTIONS ATTENDED	Thammasat University, 2009-2013 Bachelor of Political Science Melbourne University, 2018-2020 Master of Information Systems
HOME ADDRESS	Address No.392/6 Village No.20 Intakanok Rd. Ban Phai, Khon Kaen, 40110, THAILAND.
EMPLOYMENT	Thai Smile Airways Company Limited, 2013-2015: Bangkok, Thailand Position: Digital Marketing Officer Electronic Transactions Development Agency, 2021-2022: Bangkok, Thailand Position: Standard Analyst Officer
EMAIL	pacharee.phy@student.mahidol.ac.th